

第12章

防火墙技术

计算机安全本身就是一个难题，要保证联网计算机的安全性就更加困难。单台主机的管理员通过细心地选择系统软件和加强系统安全配置，也许会使其获得一定的安全性。但是，如果这台主机连到网上，情况就大不一样了。

1. 对计算机的攻击发起点数量剧增

攻击单台主机必须在能够物理接触到的前提下，通过鼠标或键盘等输入设备进入系统。物理接触这一前提使得潜在的攻击者只能存在于一个很小的范围内。联网主机则不同，只要通过网络能够到达目标主机，就存在被攻击的可能。因特网把全球成千上万的主机连接到一起，假如没有正确的防范，任何人都可以对联网计算机进行攻击。

2. 攻击方式更多，破坏性更强

单台计算机受到攻击的方式不多，影响也不太大，但是对于联网的计算机而言，受到攻击的方式增多了，邮件服务、联网的文件系统，以及数据库服务器都是潜在的危险源，同时受到攻击后导致的后果也更加严重。比如邮件服务器受到攻击，可能导致所有邮件使用者无法正常使用。此外，某些协议所采用的认证方式也存在一定的缺陷（可参考第2、3章对协议的描述），但是为了给本地用户提供相应的服务，人们还不得不使用它们。

3. 网络也暴露了计算机的可传递信任问题

一台经过安全设置的计算机本身可能是安全的，但与其相连的其他用户的计算机可能是不安全的。即使这一连接是经过认证的，并对直接攻击免疫，但是如果该连接的源头被攻破，它仍然可以成为攻击系统的桥头堡。

要成功地解决这些问题，有效的解决方案是采用防火墙。

防火墙是架设在内部网络和外部网络之间的屏障，它限制内部和外部网络数据的自由流动。如果使用得当，防火墙会大大地提高网络的安全性。然而“世界上没有绝对的东西”。任何网络都不具有绝对的安全性，做任何事情都要付出相应的代价。网络会给人们带来很多好处，与网络断开连接意味着自动放弃这些好处。在实际应用中，管理员可权衡利弊做出决策。

12.1

防火墙概述

防火墙是由软件和硬件组成的系统，它处于安全的网络（通常是内部局域网）和不安全的网络（通常是 Internet，但不局限于 Internet）之间，根据由系统管理员设置的访

问控制规则，对数据流进行过滤。

由于防火墙置于两个网络之间，因此从一个网络到另一个网络的所有数据流都要流经防火墙。根据安全策略，防火墙对数据流的处理方式有 3 种：①允许数据流通过；②拒绝数据流通过；③将这些数据流丢弃。当数据流被拒绝时，防火墙要向发送者回复一条消息，提示发送者该数据流已被拒绝。当数据流被丢弃时，防火墙不会对这些数据包进行任何处理，也不会向发送者发送任何提示信息。丢弃数据包的做法加长了网络扫描所花费的时间，发送者只能等待回应直至通信超时。

防火墙是 Internet 安全的最基本组成部分。但是，我们必须牢记，仅采用防火墙并不能给整个网络提供全局的安全性。对于防御内部的攻击，防火墙显得无能为力，同样对于那些绕过防火墙的连接（如某些人通过拨号上网），防火墙则毫无用武之地。

此外，网络管理员在配置防火墙时，必须允许一些重要的服务通过，否则内部用户就不可能接入 Internet，也不能收发电子邮件。事实上，虽然防火墙为某些业务提供了一个通道，但这也为潜在的攻击者提供了攻击内部网络的机会。攻击者可能利用此通道对内部网络发起攻击，或者注入病毒和木马。

由于防火墙是放置在两个网络之间的网络安全设备，因此以下要求必须得到满足：

- 所有进出网络的数据流都必须经过防火墙。
- 只允许经过授权的数据流通过防火墙。
- 防火墙自身对入侵是免疫的。

注意：以上要求仅是防火墙设计的基本目标。防火墙设计不可能做到万无一失，它有可能存在安全漏洞。但是，防火墙在设计中的某个细节上出现疏忽并不意味着此防火墙不可用，只能说使用了一个安全性较差的防火墙。内部网络之所以需要防火墙的保护，是因为内部网络的大多数主机不具备抵抗已知攻击的能力。在抵御攻击方面，防火墙具有不可替代的优势。

防火墙不是一台普通的主机，它自身的安全性要比普通主机更高。虽然 NIS (Network Information Service)、rlogin 等服务能为普通网络用户提供非常大的便利，但是应严禁防火墙为用户提供这些危险的服务。因此，那些与防火墙的功能实现不相关但又可能给防火墙自身带来安全威胁的网络服务和应用程序，都应当从防火墙中剥离出去。

此外，网络管理员在配置防火墙时所采用的默认安全策略是：凡是没有明确“允许的”服务，一律都是“禁止的”。防火墙的管理员不一定比普通的系统管理员高明，但他们对网络的安全性更加敏感。普通的用户只关心自己的计算机是否安全，而网络管理员关注的是整个网络的安全。网络管理员通过对防火墙进行精心配置，可以使整个网络获得相对较高的安全性。

众所周知，防火墙能够提高内部网络的安全性，但这并不意味着主机的安全不重要。即使防火墙密不透风，且网络管理员的配置操作从不出错，网络安全问题也依然存在，因为 Internet 并不是安全风险的唯一源泉，有些安全威胁就来自网络内部。内部黑客可能从网络内部发起攻击，这是一种更加严重的安全风险。除内部攻击之外，外部攻击者也企图穿越防火墙攻入内部网络。例如，黑客可以通过拨号经调制解调器池进入网络，并从网络内部对防火墙和主机发起攻击。因此，必须对内部主机施加适当的安全策略，

以加强对内部主机的安全防护。也就是说，在采用防火墙将内部网络与外部网络加以隔离的同时，还应确保内部网络中的关键主机具有足够的安全性。

一般来说，防火墙由几个部分构成。在图 12-1 中，“过滤器”用来阻断某些类型的



图 12-1 防火墙示意图

数据传输。网关则由一台或几台机器构成，用来提供中继服务，以补偿过滤器带来的影响。把网关所在的网络称做“非军事区”（Demilitarized Zone, DMZ）。DMZ 中的网关有时会得到内部网关的支援。通常，网关通过内部过滤器与其他内部主机进行开放的通信。在实际情况下，不是省略了过滤器就是省略了网关，具体情况因防火墙

的不同而异。一般来说，外部过滤器用来保护网关免受侵害，而内部过滤器用来防备因网关被攻破而造成恶果。单个或两个网关都能够保护内部网络免遭攻击。通常把暴露在外的网关主机称做堡垒主机。目前市场上常见的防火墙都有 3 个或 3 个以上的接口，同时发挥了两个过滤器和网关的功能，通过不同的接口实现 DMZ 区和内部网络的划分。从某种角度看，这种方式使防火墙的管理和维护更加方便，但是一旦防火墙受到攻击，DMZ 和内部网络的安全性同时失去保障。所以安全性与易用性往往相互矛盾，关键在于使用者的取舍。

实质上，防火墙就是一种能够限制网络访问的设备或软件。它可以是一个硬件的“盒子”，也可以是一个“软件”。今天，许多设备中均含有简单的防火墙功能，如路由器、调制解调器、无线基站、IP 交换机等。许多流行的操作系统中也含有软件防火墙。它们可以是 Windows 上运行的客户端软件，也可能是在 UNIX 内核中实现的一系列过滤规则。

现在市场上销售的防火墙的质量都非常高。自 Internet 诞生以来，防火墙技术取得了长足的进步。用户可以购买防火墙，也可以采用免费软件自己动手构造一个软件防火墙。但是，购买专业防火墙会有很多好处：第一，防火墙厂商提供的接口会更多、更全；第二，过滤深度可以定制，甚至可以达到应用级的深度过滤；第三，可以获得厂商提供的技术支持服务。而用户自行构造的软件防火墙往往不具备以上优势。

12.2

防火墙的类型和结构

防火墙从诞生至今，经过了好几代的发展，现在的防火墙已经与最初的防火墙大不相同了。防火墙理论仍在不断完善，防火墙功能也随着硬件性能的提升而不断增强。最初的防火墙依附于路由器，它只是路由器中的一个过滤模块。后来，随着过滤功能的完善和过滤深度的增加，防火墙逐步从路由器中分离出来，成为一个独立的设备。目前的防火墙甚至集成 VPN 及 IDS 等功能，防火墙在网络安全中扮演的角色越来越多，地位也越来越重要。

迄今，防火墙的发展经历了近 30 年的时间。第一代防火墙始于 1985 年前后，它几

乎与路由器同时出现,由 Cisco 的 IOS 软件公司研制。这一代防火墙称为包过滤防火墙。直到 1988 年,DEC 公司的 Jeff Mogul 根据自己的研究,才发表了第一篇描述有关包过滤防火墙过滤过程的文章。

在 1989—1990 年前后,AT&T 贝尔实验室的 Dave Presotto 和 Howard Trickey 率先提出了基于电路中继的第二代防火墙结构,此类防火墙被称为电路级网关防火墙。但是,他们既没有发表描述这一结构的任何文章,也没有发布基于这一结构的任何产品。

第三代防火墙结构是在 20 世纪 80 年代末和 20 世纪 90 年代初由 Purdue University 的 Gene Spafford、AT&T 贝尔实验室的 Bill Cheswick 和 Marcus Ranum 分别研究和开发的。这一代防火墙被称为应用级网关防火墙。在 1991 年,Ranum 的文章引起了人们的广泛关注。此类防火墙采用了在堡垒主机运行代理服务的结构。根据这一研究成果,DEC 公司推出了第一个商用产品 SEAL。

大约在 1991 年,Bill Cheswick 和 Steve Bellovin 开始了对动态包过滤防火墙的研究。1992 年,在 USC 信息科学学院工作的 Bob Braden 和 Annette DeSchon 开始研究用于“Visas”系统的动态包过滤防火墙,后来它演变为目前的状态检测防火墙。1994 年,以色列的 Check Point Software 公司推出了基于第四代结构的第一个商用产品。

关于第五代防火墙,目前尚未有统一的说法,关键在于目前还没有出现获得广泛认可的新技术。一种观点认为,在 1996 年由 Global Internet Software Group 公司的首席科学家 Scott Wiegel 开始启动的内核代理结构(Kernel Proxy Architecture)研究计划属于第五代防火墙。还有一种观点认为,在 1998 年由 NAI 公司推出的自适应代理(Adaptive Proxy)技术给代理类型的防火墙赋予了全新的意义,可以称之为第五代防火墙。

12.2.1 防火墙分类

根据防火墙在网络协议栈中的过滤层次不同,通常把防火墙分为 3 种:包过滤防火墙、电路级网关防火墙和应用级网关防火墙。每种防火墙的特性均由它所控制的协议层决定。在后面更加详细的论述中,会发现这种分类其实非常模糊。例如,包过滤防火墙运行于 IP 层,但是它可以窥视 TCP 信息,而这一操作又发生在电路层。对于某些应用级网关,由于设计原理自身就存在局限性,因此它们必须使用包过滤防火墙的某些功能。

防火墙所能提供的安全保护等级与其设计结构息息相关。一般来讲,大多数市面上销售的防火墙产品包含以下一种或多种防火墙结构:

- 静态包过滤
- 动态包过滤
- 电路级网关
- 应用层网关
- 状态检查包过滤
- 切换代理
- 空气隙

防火墙对开放系统互连(Open System Interconnection, OSI)模型中各层协议所产生

的信息流进行检查。要了解防火墙是哪种类型的结构，关键是要知道防火墙工作于 OSI 模型的哪一层上。图 12-2 给出了 OSI 模型与防火墙类型的关系。一般来说，防火墙工作于 OSI 模型的层次越高，其检查数据包中的信息就越多，因此防火墙所消耗的处理周期就越长。防火墙检查的数据包越靠近 OSI 模型的上层，该防火墙结构所提供的安全保护等级就越高，因为在高层上能够获得更多的信息用于安全决策。

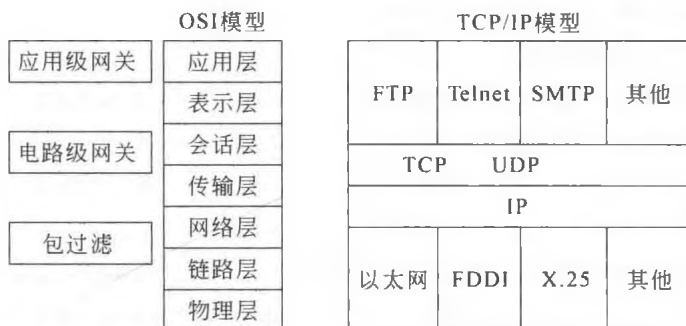


图 12-2 OSI 模型与防火墙类型的关系

TCP/IP 模型与 OSI 模型之间的对应关系如图 12-2 所示。从图中可以看出，OSI 模型与 TCP/IP 模型之间并不存在一一对应的关系。防火墙通常建立在 TCP/IP 模型基础上。为了更深入地考察防火墙的结构，下面首先看一下 IP 数据包的构成。IP 数据包结构如图 12-3 所示，它由以下几个部分组成：

- IP 头
- TCP 头
- 应用级头
- 数据/净荷头

图 12-4 和图 12-5 详细描述了 IP 头和 TCP 头包含的数据信息。

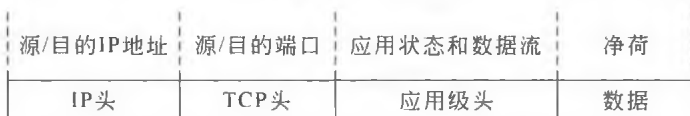


图 12-3 数据包结构



图 12-4 IP 首部数据段

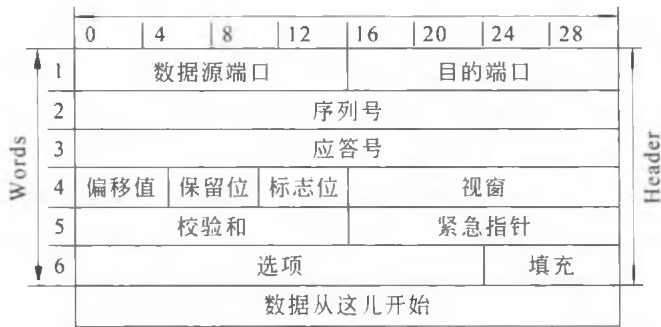


图 12-5 TCP 头部数据段

在后面的讨论中，不可避免地要提到 UNIX 操作系统和程序。Internet 上许多主机和服务器上运行的都是 UNIX 或 Linux 操作系统，许多应用级网关也采用 UNIX 来实现。因此，下面将结合 UNIX 或 Linux 系统下防火墙的实现，对某些类型的防火墙进行深入讨论。

12.2.2 网络地址转换

由于亚洲地区不是 Internet 的发源地，因此全球 IP 地址分配机构为亚洲地区分配的 IP 地址很少，亚洲国家的 IP 地址资源相对匮乏。中国在 IPv4 的 IP 地址的供需上已严重失衡。在使用 IPv4 编址方案的情况下，人们已经提出了解决地址紧缺的一些方法，如无类域间路由（CIDR）、可变长子网掩码（VLSM）及专用地址加网络地址转换（Network Address Translation, NAT）等。正因为如此，NAT 已经成为包过滤网关类防火墙的一项基本功能。使用 NAT 的防火墙具有另一个优点，它可以隐藏内部网络的拓扑结构，这在某种程度上提升了网络的安全性。

从不同的角度去理解这一概念，NAT 的分类也有所不同。例如，有些人把源网络地址转换（SNAT）和目标地址转换（DNAT）的概念理解为静态（Static）网络地址转换和动态（Dynamic）网络地址转换，而有些人却理解为源（Source）网络地址转换和目标（Destination）网络地址转换。此外，还存在端口地址转换（PAT）的概念。

所谓静态网络地址转换，是指在进行网络地址转换时，内部网络地址与外部的 Internet IP 地址是一一对应的关系。例如，将内部地址 192.168.1.100 对应转换到 202.112.58.100。在这种情况下，不需要 NAT 盒在地址转换时记录转换信息。

动态网络地址转换则不同，可用的 Internet IP 地址限定在一个范围内，而内部网络地址的范围大于 Internet IP 地址的范围。在进行地址转换时，如果 Internet IP 地址都被占用，此时从内部网络地址发出的请求会因为无地址可分配而遭到拒绝。显然，这种情形无法满足实际应用系统的需求，所以才出现了所谓的端口地址转换（PAT）的概念。

PAT 是指在进行网络地址转换时，不仅网络地址发生改变，而且协议端口也会发生改变。简单地说，PAT 在以地址为唯一标识的动态网络地址转换基础上，又增加了源端口或目的端口号作为标识的一部分。在进行地址转换时，NAT 优先进行。当合法 IP 地址分配完后，对于新来的连接请求，会重复使用前面已经分配过的合法 IP。两次 NAT 的数据包通过端口号加以区分。由于可以使用的端口范围为 1024~65535，因此一个合

法 IP 可以对应于 6 万多个 NAT 连接请求，通常可以满足几千个用户的需求。

当内部用户使用专用地址访问 Internet 时，SNAT 必须将 IP 头部中的数据源地址（专用 IP 地址）转换成合法的 Internet 地址，因为按照 IPv4 编址的规定，目标地址为专用地址的数据包在 Internet 上是无法传输的。

当 Internet 用户访问防火墙后面的服务器所提供的服务时，DNAT 必须将数据包中的目的地址转换成服务器的专用地址，使合法的 Internet IP 地址与内部网络中服务器的专用地址相对应。内部（或专用）IP 地址的范围如图 12-6 所示。

IP地址范围	总计
10.0.0.0~10.255.255.255	2^{24}
172.16.0.0~172.31.255.255	2^{20}
192.68.0.0~192.168.255.255	2^{16}

图 12-6 内部（或专用）IP 地址的范围

静态网络地址转换、动态网络地址转换和端口地址转换侧重于根据 NAT 的实现方式对 NAT 进行分类，而源地址、目标地址转换侧重于根据数据流向进行分类。静态网络地址转换不需要维护地址转换状态表，功能简单，性能较好。而动态网络地址转换和端口地址转换则必须维护一个转换表，以保证能够对返回的数据包进行正确的反向转换，因此功能更强大，但是需要更多的资源。普通边界路由器也能够实现地址转换，但由于其内存资源有限，在中型网络中使用路由器实现 NAT 功能通常不可靠。如果使用路由器做 NAT，那么在运行一段时间（通常为几个小时）后，路由器的资源将耗尽，无法继续工作。所以，通常的做法是在防火墙上实现 NAT 功能。

在实践中，实现 NAT 的路由器配置如图 12-7 所示。在图中，路由器有两个 IP 地址：

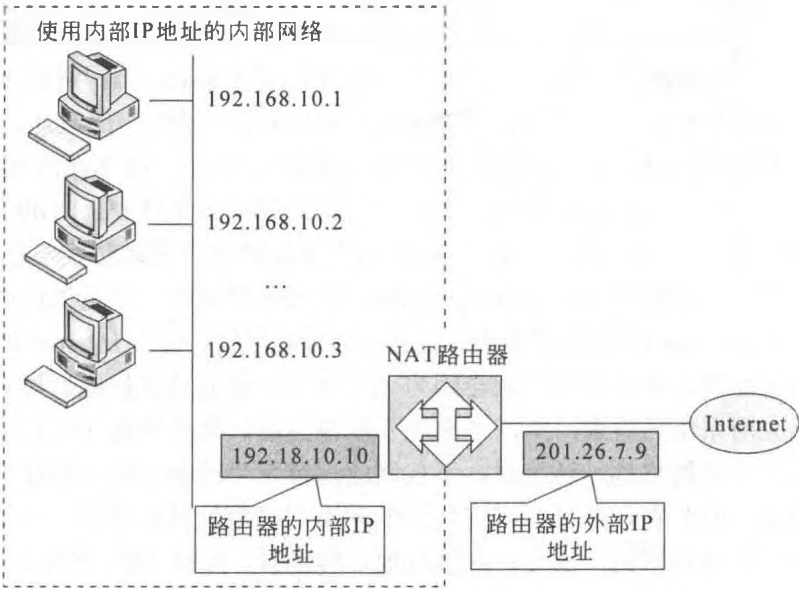


图 12-7 实现 NAT 的路由器配置

一个是内部 IP 地址，一个是外部 IP 地址。外网（Internet）中的主机通过外部 IP 地址 201.26.7.9 访问路由器，而内网中的主机则通过内部 IP 地址 192.168.10.10 访问路由器。

这意味着，外网中的主机永远只能看到一个 IP 地址，即路由器的外部 IP 地址。当数据包流过路由器时，数据包的源地址和目的地址分别为：

（1）对于所有输入数据包，不管最终的目标主机是内网中的哪一台机器，当数据包进入内部网络时，其目的地址字段总包含 NAT 路由器的外部地址。

（2）对于所有输出数据包，不管源点主机是内部网络中的哪一台机器，当数据包离开内部网络时，其源地址字段总包含 NAT 路由器的外部地址。

因此，NAT 路由器要进行如下转换工作：

（1）对于所有的输入数据包，NAT 路由器用最终目标主机的 IP 地址替换数据包的源地址（即路由器的外部地址）。

（2）对于所有输出数据包，NAT 路由器用其外部地址替换数据包的源地址（即发送数据包的内部主机的 IP 地址）。

NAT 转换过程示例如图 12-8 所示。

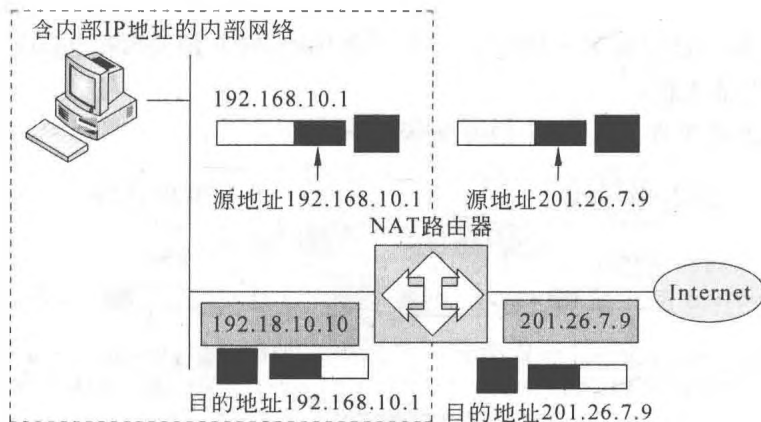


图 12-8 NAT 转换过程示例

仔细研究会发现，对于输出数据包，NAT 的工作很简单：NAT 路由器只需用 NAT 的外部地址来替换数据包中的源地址（内部主机地址）。但是，对于输入数据包，NAT 如何知道该将此数据包发给内网中的哪一台主机呢？要解决这个问题，NAT 路由器需要维护一个转换表，该表将内部主机的地址映射到外部主机的地址。这样，一旦某个内部主机发送一个数据包给外部主机，NAT 路由器就在此转换表中增加一个条目。该条目中含有内部主机的 IP 地址及目标外部主机的 IP 地址。一旦从外部主机返回了一个响应，NAT 路由器便查询转换表，决定将此响应数据包发给内网中的哪台主机。为了增进读者对 NAT 的理解，下面来看一个示例。

（1）假设一台内部主机（地址为 192.168.10.1）要向外部主机（地址为 210.10.20.20）发送一个数据包。该内部主机将该数据包发送给内部网络，该数据包将到达 NAT 路由器。此时，该数据包的源地址为 192.168.10.1，而目的地址为 210.10.20.20。

（2）NAT 路由器在转换表中增添一个条目，如表 12-1 所示。

表 12-1 在转换表中增加一个新条目

转 换 表	
内 部 地 址	外 部 地 址
192.168.10.1	210.10.20.20
...	...

(3) NAT 路由器用自己的地址（即 201.26.7.9）替换数据包中的源地址，并利用路由机制，将此数据包发送给 Internet 上的目标主机。此时，该数据包的源地址为 201.26.7.9，而目的地址为 210.10.20.20。

(4) Internet 上的外部路由器处理该数据包，并发回一个响应数据包。此时，该响应数据包的源地址为 210.10.20.20，而目的地址为 201.26.7.9。

(5) 该响应数据包到达 NAT 路由器。因为响应数据包中的目的地址与 NAT 路由器的地址匹配，所以 NAT 路由器查询转换表，以确认此转换表中是否含有外部地址为 210.10.20.20 的条目。最终，NAT 路由器找到了这个条目中含有的内部主机地址为 192.168.10.1。

(6) NAT 路由器用内部主机地址（即 192.168.10.1）替换数据包的目的地址，并将该分组发给该内部主机。

NAT 路由器的工作过程如图 12-9 所示。

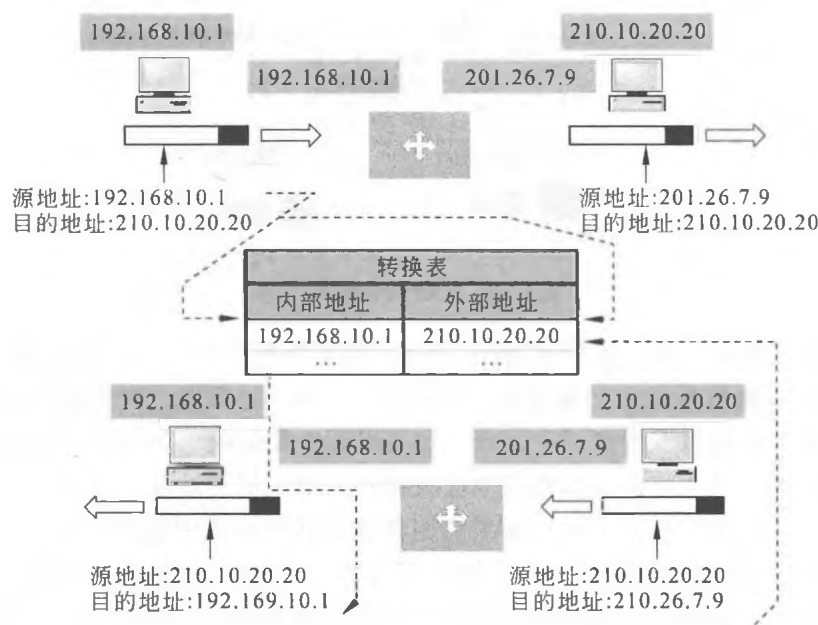


图 12-9 NAT 路由器的工作过程

在此方案中，如果有多个内部主机同时与外网的同一台主机通信，NAT 路由器如何确定应该将响应数据包发给哪一台内部主机呢？要解决此问题，需要修改 NAT 转换表，添加几列新的参数。修改后的 NAT 转换表如表 12-2 所示。

表 12-2 修改后的 NAT 转换表

内部地址	内部端口	外部地址	外部端口	NAT 端口	传输协议
192.168.10.1	300	210.10.20.20	80	14000	TCP
192.168.10.1	301	210.10.20.20	21	14001	TCP
192.168.10.2	26601	210.10.20.20	80	14002	TCP
192.168.10.3	1275	207.21.1.5	80	14003	TCP

新加列在 NAT 中所起的作用如下所述。

(1) 新加的“内部端口”一列数据标识内部主机上的应用程序所使用的端口号。对于每个应用，该端口是随机选取的。当对应于用户请求的响应数据包从外网主机发回时，内部主机需要知道该把此响应递交给哪个应用程序。这将由内部端口号确定。

(2) 新加的“外部端口”一列数据标识某一服务应用程序所使用的端口号。对于给定的服务应用程序，该端口总是固定的。例如，HTTP 服务使用 80 端口，而 FTP 服务使用 21 端口，SMTP 使用 25 端口，POP3 使用 110 端口，等等。

(3) 新加的“NAT 端口”一列数据是一个依次递增的数字，由 NAT 路由器生成。该列数据与源地址或目的地址绝无任何关系。当外部主机发回一个响应数据包时，此列中的数据才起作用。

下面将针对两种情况讨论 NAT 转换过程。

(1) 同一内部主机上的多个应用程序同时访问同一外部主机。

当地址为 192.168.10.1 的内部主机要访问地址为 210.10.20.20 的外部主机上的 HTTP 和 FTP 服务时，内部主机会动态地创建两个端口号 300 和 301，并打开两个连接。这两个连接分别与外部主机上的端口号 80 和 21 相连。当数据包从内部主机传到路由器时，NAT 路由器将数据包中的源地址（内部主机地址）替换为 NAT 路由器的地址。此外，它还要把数据包的端口号字段替换为 14000 和 14001，并把这些内容添加到 NAT 转换表中。然后，它将此数据包发给地址为 210.10.20.20 的外部主机。

当外部主机的 HTTP 服务器给 NAT 路由器发回一个响应数据包时，NAT 路由器就知道输入数据包的目的端口号为 14000。通过查询 NAT 转换表，它知道应该将此数据包发送到地址为 192.168.10.1 的内部主机的 300 端口。同样，当从外部主机的 FTP 服务器上返回一个响应时，NAT 路由器就知道该数据包的目的端口为 14001。通过查询 NAT 转换表，它知道应该将此数据包发送到地址为 192.168.10.1 的内部主机的 301 端口。

(2) 多个内部主机同时访问同一外部主机。

根据以上讨论，读者很容易理解 NAT 路由器如何处理此类情况。表 12-2 的第 4 行有一个条目，该条目表明有一个地址为 192.168.10.2 的内部主机，需要使用 26601 端口访问地址为 210.10.20.20 的外网主机上的 HTTP 服务。当外部主机响应时，通过查询路由表，NAT 路由器将响应数据包分发到地址为 192.168.10.2 的内部主机的 26601 端口。

为了完整地描述 NAT 存在的各种情况，在表 12-2 的第 5 行中，给出了另一个内部主机与另一个外部主机通信时 NAT 转换表中所增加的条目。读者可以自行分析其工作过程。

12.3

静态包过滤器

静态包过滤防火墙可以采用路由器上的过滤模块来实现，而且具有较高的安全性。由于可以直接使用路由器软件的过滤功能，无须购买专门的设备，因此可以减少投资。路由器是内部网络接入 Internet 所必需的设备，每个网络的入口都配备路由器。直接使用路由器软件作为过滤器，不需要额外付费。当然，用户也可以购买专门的包过滤防火墙。

12.3.1 工作原理

顾名思义，静态包过滤防火墙采用一组过滤规则对每个数据包进行检查，然后根据检查结果确定是转发、拒绝还是丢弃该数据包。这种防火墙对从内网到外网和从外网到内网两个方向的数据包进行过滤，其过滤规则基于 IP 与 TCP/UDP 头中的几个字段。图 12-10 说明了静态包过滤防火墙的设计思想。



图 12-10 静态包过滤防火墙的设计思想

静态包过滤防火墙的操作如图 12-11 所示，主要实现如下 3 个主要功能。

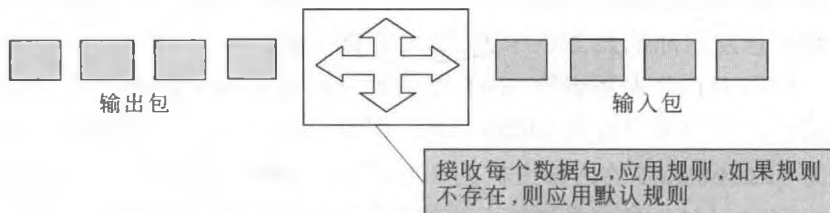


图 12-11 静态包过滤防火墙的操作

(1) 接收每个到达的数据包。

(2) 对数据包采用过滤规则，对数据包的 IP 头和传输字段内容进行检查。如果数据包的头信息与一组规则匹配，则根据该规则确定是转发还是丢弃该数据包。

(3) 如果没有规则与数据包头信息匹配，则对数据包施加默认规则。默认规则可以丢弃或接收所有数据包。默认丢弃数据包规则更严格，而默认接收数据包规则更开放。通常，防火墙首先默认丢弃所有数据包，然后再逐个执行过滤规则，以加强对数据包的过滤。

静态包过滤防火墙是最原始的防火墙，静态数据包过滤发生在网络层上，也就是 OSI 模型的第 3 层上，如图 12-12 所示。

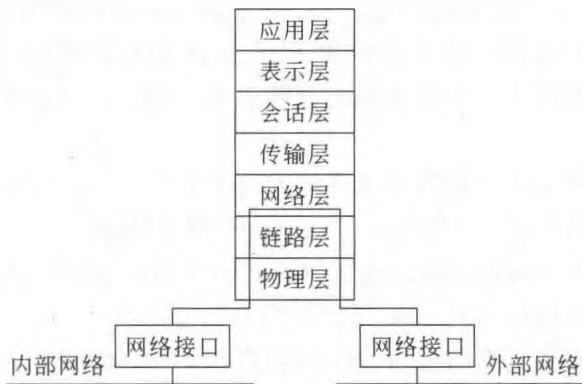


图 12-12 工作于网络层的静态包过滤

对于静态包过滤防火墙来说，决定接收还是拒绝一个数据包，取决于对数据包中 IP 头和协议头等特定域的检查 and 判定。这些特定域包括：①数据源地址；②目的地址；③应用或协议；④源端口号；⑤目的端口号。静态包过滤防火墙 IP 数据包结构如图 12-13 所示。

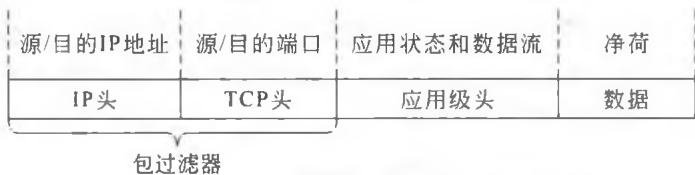


图 12-13 静态包过滤防火墙 IP 数据包结构

在每个包过滤器上，安全管理员要根据企业的安全策略定义一个表单，这个表单也被称为访问控制规则库。该规则库包含许多规则，用来指示防火墙应该拒绝还是接收该数据包。在转发某个数据包之前，包过滤器防火墙将 IP 头和 TCP 头中的特定域与规则库中的规则逐条进行比较。防火墙按照一定的次序扫描规则库，直到包过滤器发现一个特定域满足包过滤规则的特定要求时，才对数据包做出“接收”或“丢弃”的判决。如果包过滤器没有发现一个规则与该数据包匹配，那么它将对其施加一个默认规则。该默认规则在防火墙的规则库中有明确的定义，一般情况下防火墙将不满足规则的数据包丢弃。

在包过滤器所使用的默认规则的定义上，有两种思路：①容易使用；②安全第一。“容易使用”的倡导者所定义的默认规则是“允许一切”，即除非该数据流被一个更高级规则明确“拒绝”，否则该规则允许所有数据流通过。“安全第一”的倡导者所定义的默认规则是“拒绝一切”，即除非该数据流得到某个更高级规则明确“允许”，否则该规则将拒绝任何数据包通过。

在静态包过滤规则库内，管理员可以定义一些规则决定哪些数据包可以被接收，哪些数据包将被拒绝。管理员可以针对 IP 头信息定义一些规则，以拒绝或接收那些发往或来自某个特定 IP 地址或某一 IP 地址范围的数据包。管理员可以针对 TCP 头信息定义一些规则，用来拒绝或接收那些发往或来自某个特定服务端口的数据包。

例如，管理员可以定义一些规则，允许或禁止某个 IP 地址或某个 IP 地址范围的用户使用 HTTP 服务浏览受保护的 Web 页面。同样，管理员也可以定义一些规则，允许某个可信的 IP 或 IP 地址范围内的用户使用 SMTP 服务访问受保护的 Mail 服务器上的文件。管理员还可以定义一些规则，封堵某个 IP 地址或 IP 地址范围内的用户访问某个受保护的 FTP 服务器。图 12-14 为一个静态包过滤防火墙规则表。该过滤规则表决定是允许转发还是丢弃数据包。

根据该规则表，静态包过滤防火墙采取的过滤动作如下：

- (1) 拒绝来自 130.33.0.0 的数据包，这是一种保守策略。
- (2) 拒绝来自外部网络的 Telnet 服务（端口号为 23）的数据包。
- (3) 拒绝试图访问内网主机 193.77.21.9 的数据包。
- (4) 禁止 HTTP 服务（端口号为 80）的数据包输出，此规则表明，该公司不允许员工浏览 Internet。

包过滤器的工作原理非常简单，它根据数据包的源地址、目的地址或端口号确定是否丢弃数据包。也就是说，判决仅依赖于当前数据包的内容。根据所用路由器的类型，过滤可以发生在网络入口处，也可以发生在网络出口处，或者在入口和出口同时对数据包进行过滤。网络管理员可以事先准备好一个访问控制列表，其中明确规定哪些主机或服务是可接受的，哪些主机或服务是不可接受的。采用包过滤器，能够非常容易地做到在网络层上允许或拒绝主机的访问。例如，可以做到允许主机 A 和主机 B 互访，或者拒绝除主机 A 之外的其他主机访问主机 B。

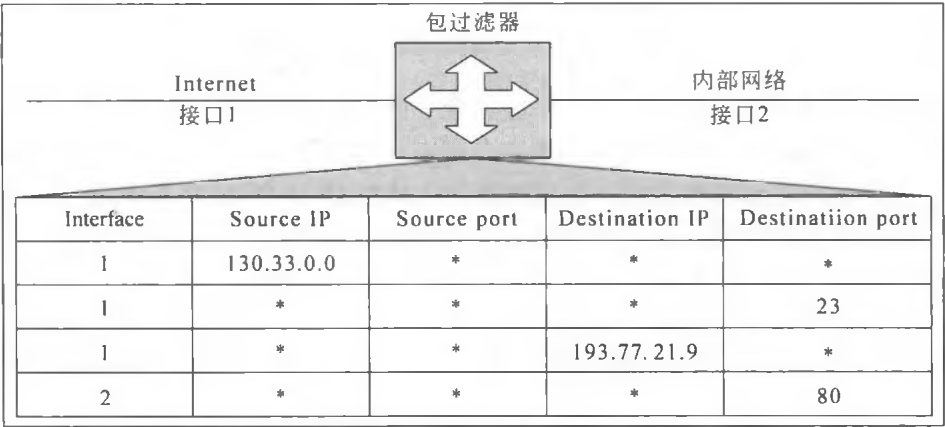


图 12-14 静态包过滤防火墙规则表

包过滤防火墙的配置分 3 步进行：第一，管理员必须明确企业网络的安全策略，即必须搞清楚什么是允许的、什么是禁止的；第二，必须用逻辑表达式清楚地表述数据包的类型；第三，这也是最难的一步，必须用设备提供商可支持的语法重写这些表达式。

根据静态包过滤的工作原理，可以很容易地构建一个静态包过滤防火墙。实际上，制定精确的静态包过滤规则可能更需要花费一番心思。由于每个网站的安全策略都不一样，因此不可能为每个网站使用的包过滤器设置精确的过滤规则。在本节中，仅提供几个合理的规则配置样本供大家参考。表 12-3 和表 12-4 提供了两个配置样本，它们部分

来自美国计算机应急响应中心（CERT）的建议书。最后一条规则的作用是阻止所有其他 UDP 服务，对这条规则人们是有争议的。

表 12-3 某大学的防火墙过滤规则设置

action	src	port	dest	port	flags	comment
allow	secondary	*	our-dns	53	TCP	allow secondary nameserver access
block	*	*	*	53	TCP	no other DNS zone transfers
allow	*	*	*	53	UDP	permit UDP DNS queries
allow	ntp.outside	123	ntp.inside	123	UDP	ntp time access
block	*	*	*	69	UDP	no access to our tftpd
block	*	*	*	87	TCP	the link service is often misused
block	*	*	*	111	TCP	no TCP RPC and ...
block	*	*	*	111	UDP	no UDP RPC and no ...
block	*	*	*	2049	UDP	NFS. This is hardly a guarantee
block	*	*	*	2049	TCP	TCP NFS is coming: exclude it
block	*	*	*	512	TCP	no incoming "r" commands...
block	*	*	*	513	TCP	...
block	*	*	*	514	TCP	...
block	*	*	*	515	TCP	no external lpr
block	*	*	*	540	TCP	uucpd
block	*	*	*	6000-6100	TCP	no incoming X
allow	*	*	adminnet	443	TCP	encrypted access to transcript mgr
block	*	*	adminnet	*	TCP	nothing else
block	pclab-net	*	*	*	TCP	anon. students in pclab can't go outside
block	pclab-net	*	*	*	UDP	... not even with TFTP and the like!
allow	*	*	*		TCP	all other TCP is OK
block	*	*	*		UDP	suppress other UDP for now

表 12-4 某公司的防火墙过滤规则设置

action	src	port	dest	port	flags	comment
allow	*	*	mailgate	25	TCP	inbound mail access
allow	*	*	mailgate	53	UDP	access to our DNS
allow		*	mailgate	53	TCP	secondary nameserver access
allow	*	*	mailgate	23	TCP	incoming telnet access
allow		123	ntp.inside	123	UDP	external time source
allow		*	*	*	TCP	outgoing TCP packets are OK
allow	*	*	inside-net	*	ACK	return ACK packets are OK
block	*	*	*	*	TCP	nothing else is OK
block	*	*	*	*	UDP	block other UDP, too

今天的校园网络趋向于对 Internet 连接采取开放的安全策略。出于安全的考虑，仍然需要对某些危险的服务施加限制，如 NFS、TFTP 和 Telnet 等。虽然这些服务有时会给人们的工作和学习带来方便，但是它们会带来更大的安全隐患，因此尽量减少对外提供这些服务。在表 12-3 中，假设大学中有一个实验室 PC Lab，若允许该实验室的主机访问 Internet，可能会带来安全风险。因此，在网络管理员在配置防火墙规则时，应禁止该实验室的主机访问 Internet。还有一条规则允许通过 HTTPS 服务访问管理域中的计算机。该服务采用 443 端口，需要强认证和加密措施。

与校园网络不同，许多公司或家庭的网络希望禁止大多数来自 Internet 的访问，而允许大多数去往 Internet 的连接请求。在这类网络中，可以让一个网关接收进入内网的邮件，并为公司的内部主机提供域名解析服务。在表 12-4 中，采用了一条规则禁止 23 号端口上的 Telnet 服务。如果公司的邮件服务器和 DNS 服务器交由 ISP 托管，那么可以进一步简化这些规则。

12.3.2 安全性讨论

因为防火墙对这些规则的检查是按顺序进行的，所以决定包过滤规则的先后次序是一项很困难的事情。在把包过滤规则输入到规则库时，管理员必须要特别小心。即使管理员已经按照一定的先后次序创建了规则，包过滤器还存在先天的缺陷：包过滤器仅检查数据的 IP 头和 TCP 头，它不可能区分真实的 IP 地址和伪造的 IP 地址。若一个伪造的 IP 地址满足包过滤规则，并同时满足其他规则的要求，则该数据包将被允许通过。

假设管理员精心创建了一条规则，该规则指示数据包过滤器丢弃所有来自未知源地址的数据包。这条包过滤规则虽然会极大地增大黑客访问某些可信服务器的难度，但不能彻底杜绝这类访问。黑客只须用某个已知可信客户机的源地址替代恶意数据包的实际源地址就可以达到目的。把这种形式的攻击称为 IP 地址欺骗（IP Address Spoofing）。用 IP 地址欺骗攻击来对付包过滤防火墙是非常有效的。美国计算机应急响应中心（CERT）已经收到大量 IP 欺骗攻击的报告，报告显示许多攻击已成功侵入网络。尽管包过滤防火墙的性能非常具有吸引力，但是包过滤防火墙的固有结构决定了其安全性不够高，那些水平高超的黑客有可能穿越包过滤防火墙而进入受保护的内部网络。

同样，我们注意到静态包过滤防火墙并没有对数据包做太多的检查。请记住，静态包过滤防火墙仅检查那些特定的协议头信息：① 源/目的 IP 地址；② 源/目的端口号（服务）。因此，黑客可将恶意的命令或数据隐藏在那些未经检查的头信息中。更危险的是，由于静态包过滤防火墙没有检查数据包的净荷部分，使黑客有机会将恶意的命令或数据隐藏到数据净荷中。这一攻击方法通常被称做“隐信道攻击”（Covert Channel Attack）。目前，这种形式的攻击越来越多，必须加倍小心。

最后需说明的是，包过滤防火墙并没有“状态感知”（State Aware）的能力。管理员必须为某个会话的两端都配置相应的规则以保护服务器。例如，要允许用户访问某个受保护的 Web 服务器，管理员必须创建一条规则，该规则既允许来自远端客户机的请求进入内部网络，又允许来自 Web 服务器的响应去往 Internet。值得注意的是，现在人们在使用 FTP 和 E-mail 等服务时，需要静态包过滤防火墙能够动态地为这些服务分配端口，

所以管理员必须为静态包过滤规则打开所有的端口。

静态包过滤防火墙有如下优点。

(1) **对网络性能有较小的影响**。由于包过滤防火墙只是简单地根据地址、协议和端口进行访问控制,因此对网络性能的影响比较小。只有当访问控制规则比较多时,才会感觉到性能的下降。

(2) **成本较低**。路由器通常集成了简单包过滤的功能,基本上不再需要单独的防火墙设备实现静态包过滤功能,因此从成本方面考虑,简单包过滤的成本非常低。

静态包过滤防火墙有如下缺点。

(1) **安全性较低**。由于包过滤防火墙仅工作于网络层,其自身的结构设计决定了它不能对数据包进行更高层的分析和过滤。因此,包过滤防火墙仅提供较低水平的安全性。

(2) **缺少状态感知能力**。一些需要动态分配端口的服务需要防火墙打开许多端口,这就增大了网络的安全风险,从而导致网络整体安全性不高。

(3) **容易遭受 IP 欺骗攻击**。由于简单的包过滤功能没有对协议的细节进行分析,因此有可能遭受 IP 欺骗攻击。

(4) **创建访问控制规则比较困难**。包过滤防火墙由于缺少状态感知的能力而无法识别主动方与被动方在访问行为上的差别。要创建严密有效的访问控制规则,管理员需要认真地分析和研究一个组织机构的安全策略,同时必须严格区分访问控制规则的先后次序,这对于新手而言是一个比较困难的问题。

12.4

动态包过滤防火墙

动态包过滤器是最普遍使用的一种防火墙技术,既具有很高的安全性,又具有完全的透明性。动态包过滤器的设计目标是允许所有的客户端软件不加修改即可工作,并让网络管理员仍然对流过防火墙的数据流施加完全的控制。静态包过滤防火墙的规则表是固定的,而动态包过滤防火墙可以根据网络当前的状态检查数据包,即根据当前所交换的信息动态调整过滤规则表。

12.4.1 工作原理

动态(状态)包过滤器是在静态包过滤防火墙的基础上发展而来的。由于动态包过滤防火墙继承了静态包过滤防火墙的某些特征,因此它具有静态包过滤防火墙固有的许多不足。但是,动态包过滤防火墙与静态包过滤防火墙有显著的不同,即它具有“状态感知”的能力。

典型的动态包过滤防火墙也和静态包过滤防火墙一样,都工作在网络层,即 OSI 模型的第 3 层。更先进的动态包过滤防火墙可以在 OSI 的传输层(第 4 层)上工作。在传输层上,动态包过滤防火墙可以收集更多的状态信息,从而增加过滤的深度。工作于传输层的动态包过滤防火墙如图 12-15 所示。

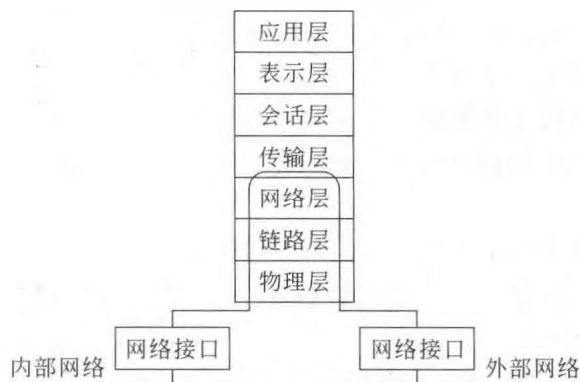


图 12-15 工作于传输层的动态包过滤防火墙

通常，动态包过滤防火墙做出转发还是丢弃一个数据包的判断，取决于对数据包的 IP 头和协议头的检查。动态包过滤防火墙所检查的数据包头信息包括：①数据源地址；②目的地址；③应用或协议；④源端口号；⑤目的端口号。

动态包过滤防火墙在对数据包的过滤方面，呈现出与普通包过滤防火墙非常相似的特征。如果数据包满足规则，如数据包的端口号或 IP 地址是可接受的，则被允许通过。但动态包过滤防火墙与普通的包过滤防火墙相比，还有一个不同点：它首先对外出的数据包身份进行记录，此后若有相同连接的数据包进入防火墙，它就直接允许这些数据包通过。

例如，动态包过滤防火墙的一条规则是：如果从外网输入防火墙的 TCP 数据包是对从内网发出的 TCP 数据包的回应，则允许这些 TCP 数据包通过防火墙。由此可以看出，动态包过滤防火墙直接对“连接”进行处理，而不是仅对数据包头信息进行检查。因此，它可以用来处理 UDP 和 TCP。即使 UDP 缺少 ACK 标志位，它也可以对其进行过滤。

注意：动态包过滤防火墙需要对已建连接和规则表进行动态维护，因此它是动态的和有状态的。动态包过滤防火墙根据规则表对数据包进行过滤，图 12-16 显示了其工作原理。

简而言之，典型的动态包过滤防火墙能够感觉到新建连接与已建连接之间的差别。一旦连接建立，它就会将该连接的状态记于 RAM 中的一个表单中。后续的数据包与 RAM 表单中的状态信息进行比较，这一比较由操作系统内核层的软件实现。当动态包过滤防火墙发现进来的数据包是已建连接的数据包时，就会允许该数据包直接通过而不做任何检查。由于避免了对进入防火墙的每个数据包都进行规则库的检查，并且在内核层实现了数据包与已建连接状态的比较，因此动态包过滤防火墙的性能比静态包过滤防火墙的性能有很大的提高。

在概念上，实现动态包过滤器有两种主要的方式。一种方式是实时地改变普通包过滤器的规则集。许多采用这种方式的防火墙实现不是非常令人满意。包过滤器的规则集的创建是一项非常细致的工作，而且规则的次序也很重要。我们通常搞不清楚对规则集所做的哪些改变是有利的，哪些改变是有害的。

此外，还有另一种实现动态包过滤防火墙的方式。此方式不需要检查规则表，而是采用类似电路级网关的方式转发数据包。所有进入防火墙的呼叫连接将终止于防火墙，

然后防火墙再与目标主机建立新的连接。防火墙在两个连接之间来回复制数据。

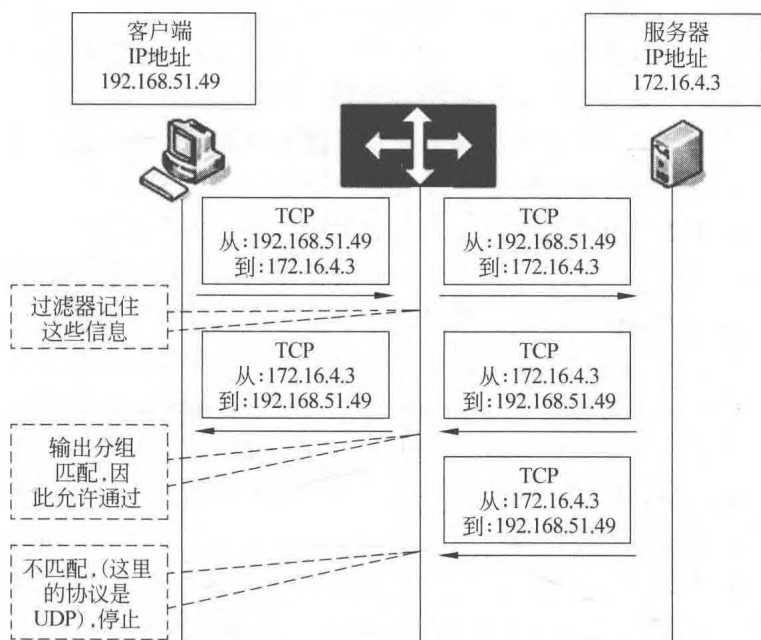


图 12-16 动态包过滤防火墙的工作原理

为了搞清其工作原理，下面再回忆一下 TCP 连接建立的过程。一个 TCP 连接可以用以下 4 个标准参数来描述：

`<localhost, localport, remotehost, remoteport>`

但是，remotehost 不必是一台特定的机器，它可以是声明使用此 IP 地址的任何进程。采用此设计的防火墙可以用任意的主机地址作为回应。当防火墙继续向真正的目标主机发起连接请求的时候，它可以使用主叫的 IP 地址，而不采用其真实的 IP 地址作为回应。动态包过滤防火墙发起重新连接示意图如图 12-17 所示。

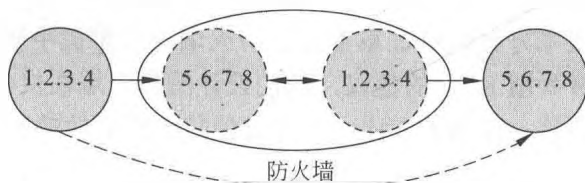


图 12-17 动态包过滤防火墙发起重新连接示意图

在图 12-17 中，虚线箭头表示意向连接，实线箭头表示真实的连接。防火墙在中间起着中继数据包的作用。对通信双方来说，防火墙既是通信的起点，也是通信的终点。防火墙对连接的识别不仅基于以上 4 个标准参数，而且基于网络接口。

12.4.2 安全性讨论

前面曾提到，普通的包过滤器存在一定的局限性。由于某些动态包过滤器增添了许

多新的功能，从而有效地解决了普通包过滤防火墙存在的问题。

在这些问题中，人们最关注 FTP 数据通道的安全问题。在对特定应用缺乏了解的前提下，防火墙根本不可能透明地处理 FTP 服务。因此，动态包过滤防火墙通常要对 21 号端口的连接（即 FTP 命令通道）进行特别处理。动态包过滤防火墙首先对命令数据流进行扫描，然后用 PORT 命令的各种参数更新过滤器规则表。若动态包过滤器限制内网的数据包流出，它也应该对 PASV 命令做相同的处理。

对于 RPC、H.323 及同类协议，动态包过滤防火墙也采取相似的策略。通过检查数据包的内容，防火墙可以控制内部（或外部）RPC 服务的调用。换言之，动态包过滤防火墙已经跳出了狭义的数据包过滤的概念，步入了“连接过滤”的范畴。

在现实中，动态包过滤防火墙主要在以下两个方面存在性能上的差异。

（1）是否支持对称多处理技术（Symmetrical Multi-Processing, SMP）。SMP 是指在一个计算机上汇集了一组处理器（多个 CPU），各个 CPU 之间共享内存子系统及总线结构。它是相对非对称多处理技术而言的应用十分广泛的并行技术。在防火墙设计中采用此技术可以大大提高防火墙的性能。

在编写防火墙软件时，如果采用了 SMP 技术，那么每增加一个处理器就会使防火墙的性能提高 30%。很遗憾，当前许多动态包过滤防火墙的实现方案均以单线程进程工作，不能充分利用 SMP 的优势，为了克服单线程带来的性能限制，许多防火墙厂家采用强大且昂贵的基于精简指令集（Reduced Instruction Set Computing, RISC）的处理器，以获取高性能。随着处理器性能的提高及多处理器服务器的广泛应用，单线程的局限性已经非常明显。例如，在昂贵的 RISC 服务器上运行防火墙软件只能达到 150Mb/s 的动态包过滤吞吐率，而在廉价的 Intel 多处理器服务器上运行防火墙软件可以获得 600Mb/s 以上的动态包过滤吞吐率。

（2）体现在连接建立的方式上。几乎每个防火墙厂商都在建立连接表（Connection Table）方面有自己的专利技术。但是，除了上面讨论的区别之外，动态包过滤防火墙的基本操作在本质上都是相同的。

为了突破基于单线程的动态包过滤防火墙的性能极限，有些厂家在防火墙建立连接时采取了非常危险的技术方案。RFC 草案建议防火墙在 3 步握手协议完成后才能建立连接，而有些厂家并没有采用 RFC 的建议，他们设计的防火墙在接收到第一个 SYN 数据包时就打开一个新的连接。实际上，这一设计将使防火墙后面的服务器容易遭到伪装 IP 地址攻击。

黑客发动的匿名攻击有时更具有危险性。与静态包过滤防火墙相似，假设管理员为防火墙创建了一条规则，指示包过滤器丢弃所有包含未知源地址的数据包。这条规则虽然使黑客的攻击变得非常困难，但是黑客仍然可以采用合法的 IP 地址访问防火墙后面的服务器。黑客可以将恶意数据包中的源地址替换成某个可信客户机的源地址。在此攻击方法中，黑客必须采用可信主机的 IP 地址，并通过 3 步握手建立连接。

如果防火墙厂商没有在连接建立的过程中采用 RFC 草案的建议，即没有执行 3 步握手协议就打开了一条连接，黑客就可以伪装成一台可信的主机，对防火墙或受防火墙保护的服务器发动单数据包攻击（Single-Packet Attack），而黑客却完全保持匿名。对于管

理员来说,他们并不清楚所使用的防火墙产品具有此种缺陷。长期以来,各种单数据包攻击(如 LAND、Ping of Death 和 Tear Drop 等)一直困扰着管理员。一旦管理员知道了防火墙设计上存在缺陷,他们就不会对发生上述攻击感到吃惊。

总之,动态包过滤防火墙的优点如下所述:

(1) 当动态包过滤防火墙设计采用 SMP 技术时,对网络性能的影响非常小。采用 SMP 的系统架构,防火墙可以由不同的处理器分担包过滤处理任务。即使在主干网络上使用动态包过滤防火墙,它也可以满足主干网络对防火墙性能的需求。

(2) 动态包过滤防火墙的安全性优于静态包过滤防火墙。由于具有了“状态感知”能力,所以防火墙可以区分连接的发起方与接收方,也可以通过检查数据包的状态阻断一些攻击行为。与此同时,对于不确定端口的协议数据包,防火墙也可以通过分析打开相应的端口。防火墙所具备的这些能力使其安全性有了很大的提升。

(3) 动态包过滤防火墙的“状态感知”能力也使其性能得到了显著提高。由于防火墙在连接建立后保存了连接状态,当后续数据包通过防火墙时,不再需要复杂的规则匹配过程,这就减少了由于访问控制规则数量的增加对防火墙性能造成的影响,因此其性能比静态包过滤防火墙好很多。

(4) 如果不考虑所采用的操作系统的成本,动态包过滤防火墙的成本也很低。

动态包过滤防火墙的缺点如下所述:

(1) 仅工作于网络层,因而仅检查 IP 头和 TCP 头。

(2) 由于没有对数据包的净荷部分进行过滤,因此仍然具有较低的安全性。

(3) 容易遭受伪装 IP 地址欺骗攻击。

(4) 难于创建规则,管理员创建规则时必须要考虑规则的先后次序。

(5) 如果动态包过滤防火墙连接在建立时没有遵循 RFC 建议的 3 步握手协议,就会引入额外的风险。如果防火墙在连接建立时仅使用两次握手,很可能导致防火墙在 DoS/DDoS 攻击时因耗尽所有资源而停止响应。

12.5 电路级网关

由于简单包过滤防火墙的缺点十分明显,因此后人提出了所谓电路级网关的理论。然而,电路级网关理论并没有获得很大的进展,目前通常作为应用代理服务器的一部分在应用代理类型的防火墙中实现。

电路级网关又称做线路级网关,当两个主机首次建立 TCP 连接时,电路级网关在两个主机之间建立一道屏障。电路级网关的作用就好像一台中继计算机,用来在两个连接之间来回地复制数据,也可以记录或缓存数据。此方案采用 C/S 结构,网关充当了服务器的角色,而内部网络中的主机充当了客户机的角色。当一个客户机希望连接到某个服务器时,它首先要连接到中继主机上,然后,中继主机再连接到服务器上。对服务器来说,该客户机的名称和 IP 地址是不可见的。

当有来自 Internet 的请求进入时,它作为服务器接收外来请求,并转发请求。当有

内部主机请求访问 Internet 时，它则担当代理服务器的角色。它监视两主机建立连接时的握手信息，如 SYN、ACK 和序列号等是否合乎逻辑，判定该会话请求是否合法。在有效会话连接建立后，电路级网关仅复制、传递数据，而不进行过滤。电路级网关的工作原理如图 12-18 所示。在图 12-18 中，电路级网关仅用来中继 TCP 连接。为了增强安全性，电路级网关可以采取强认证措施。

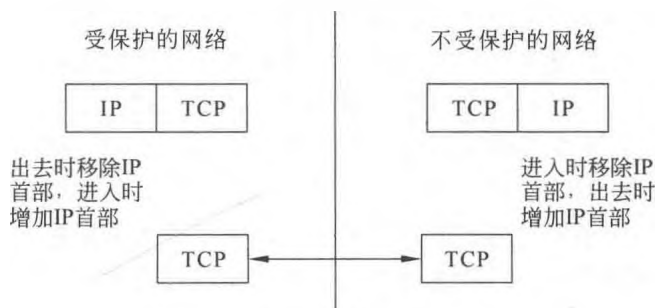


图 12-18 电路级网关的工作原理

在整个过程中，IP 数据包不会实现端到端的流动，这是因为中继主机工作于 IP 层以上。所有在 IP 层上可能出现的碎片攻击、Firewalking 探测等问题都会在中继主机上终结。对于有问题的 IP 数据流，中继主机能很好地加以处理。而在中继主机的另一端，它能发送正常的 TCP/IP 数据包。电路级网关在两个没有任何 IP 连通性的网络之间架起了一道桥梁。

在有些实现方案中，电路连接可自动完成。通过中继主机，特定的 TCP 服务可由外部主机到达内部的数据库主机。在 Internet 上，有很多实现这一功能的软件，如 `tcprelay` 就是一个 TCP 中继程序。

在另外一些实现方案中，连接服务需要知道确切的目的地址。此时，主叫主机和网关之间要运行一个简单的协议。此协议描述了主叫主机期望连接的目标主机和使用的服务。主叫用户首先向网关的 TCP 端口发出连接请求，然后网关再尝试与目标主机连接。一旦连接建立起来，中继程序就会在进出网关的两个方向上复制数据。

12.5.1 工作原理

电路级网关工作于会话层，即 OSI 模型的第 5 层，如图 12-19 所示。在许多方面，电路级网关仅仅是包过滤防火墙的一种扩展，它除了进行基本的包过滤检查之外，还要增加对连接建立过程中的握手信息及序列号合法性的验证。

在打开一条通过防火墙的连接或电路之前，电路级网关要检查和确认 TCP 及 UDP 会话。因此，电路级网关所检查的数据比静态包过滤防火墙或动态包过滤防火墙所检查的数据更多，安全性也更高。

通常，判断是接收还是丢弃一个数据包，取决于对数据包的 IP 头和 TCP 头的检查，如图 12-20 所示。电路级网关检查的数据包括：①源地址；②目的地址；③应用或协议；④源端口号；⑤目的端口号；⑥握手信息及序列号。

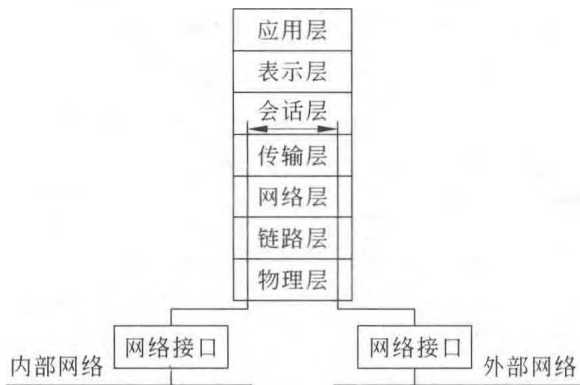


图 12-19 工作于会话层的电路级网关

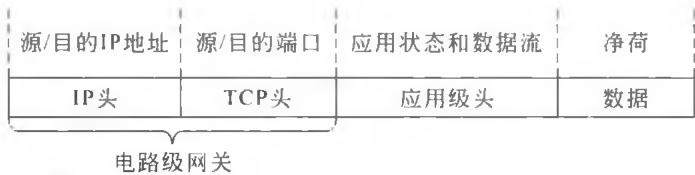


图 12-20 电路级网关过滤的 IP 数据包信息

与包过滤防火墙类似，电路级网关在转发一个数据包之前，首先将数据包的 IP 头和 TCP 头与由管理员定义的规则表相比较，以确定防火墙是将数据包丢弃还是让数据包通过。在可信客户机与不可信主机之间进行 TCP 握手通信时，仅当 SYN 标志、ACK 标志及序列号符合逻辑时，电路级网关才判定该会话是合法的。

如果会话是合法的，包过滤器就开始对规则进行逐条扫描，直到发现其中一条规则与数据包中的有关信息一致。如果包过滤器没有发现适合该数据包的规则，它就会对该数据包施加一条默认规则。在防火墙的规则表中，这条默认规则有明确的定义，通常是指示防火墙将不满足规则的数据包丢弃。

事实上，电路级网关在其自身与远程主机之间建立一个新的连接，而这一切对内网中的用户来说是完全透明的。内网用户不会意识到这些，他们一直认为自己正与远程主机直接建立连接。在图 12-21 中，电路级网关将输出数据包的源地址改为自己的 IP 地址。因此，外部网络中的主机不会知道内部主机的 IP 地址。图中的单向箭头只是为了说明这一概念，实际上箭头应是双向的。

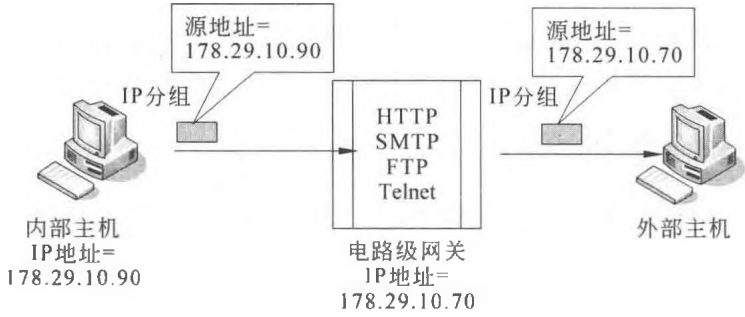


图 12-21 电路级网关的工作原理

电路中继通常在两个独立的网络之间创建特定的连接。在 Internet 的早期,许多公司的内部网均在电路级上与 Internet 隔离。SOCKS 就是一个普通的电路级网关。SOCKS 最初是由 David 和 Michelle Koblas 设计并开发的,现在已得到广泛应用。通过合理配置 SOCKS 协议,可以使用 SOCKS 中继主机作为电路级网关。

SOCKS 其实是一种网络代理协议。一台使用专用 IP 地址的内部主机可通过 SOCKS 服务器获得完全的 Internet 访问。具体网络拓扑结构是:用一台运行 SOCKS 的服务器(双宿主主机)连接内部网和 Internet,内部网主机使用的都是专用 IP 地址。内部网主机请求访问 Internet 时,首先与 SOCKS 服务器建立一个 SOCKS 通道,然后再将请求通过这个通道发送给 SOCKS 服务器;SOCKS 服务器在收到客户请求后,向 Internet 上的目标主机发出请求;得到响应后,SOCKS 服务器再通过先前建立的 SOCKS 通道将数据返回给内网主机。当然,在 SOCKS 通道的建立过程中可能有一个用户认证的过程。

典型的 SOCKS 连接如图 12-22 所示。在图中,内部网中的客户机通过 SOCKS 接口与中继主机的接口 A 相连,而 Internet 则通过接口 B 与中继主机相连。

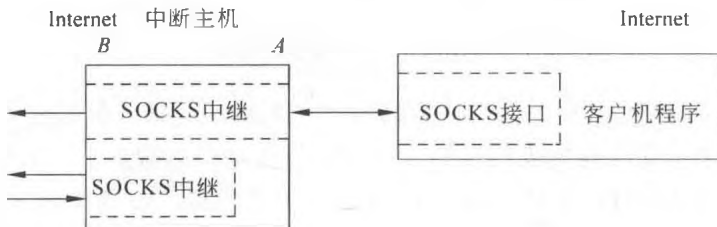


图 12-22 典型的 SOCKS 连接

电路级网关在设计上要能够中继 IP 连接,IP 地址对服务器来说是不可见的。中继请求会到达如图 12-22 所示的接口 A。如果在接口 B 上也提供该服务,外部用户就会通过中继主机发起连接。现在有很多黑客工具可以用来扫描中继服务器,以发现其存在的漏洞。

显然,必须对中继服务器施加控制。控制措施可采用各种形式,例如,可以对端口的持续时间加以限制,也可以要求列出允许访问该端口的外部用户名单,甚至可以对内部用户的连接建立请求进行用户认证。当然,到底采用什么措施要视具体情况而定。

电路级网关,包括后面要介绍的应用级网关,都非常适合于某些 UDP 应用。此时,必须修改客户机程序,以创建一条通向某种代理进程的虚电路。该电路提供了足够的信息,让 UDP 应用安全地通过过滤器。实际的目的地和源地址则被隐蔽地发送。然而,由于各种服务均需要特定的本地端口号,因此这一设计仍然存在问题。

12.5.2 安全性讨论

电路级网关完全是从包过滤防火墙基础上演化而来的,它与包过滤防火墙一样,工作于 OSI 模型的低层上,因此对网络性能有较小的影响。然而,一旦电路级网关建立一个连接,任何应用均可以通过该连接运行,这是因为电路级网关仍然是在 OSI 模型的会话层和网络层上对数据包进行过滤的。换句话说,电路级网关不能对可信网络与不可信

网络之间中继的数据包内容进行检查。这就存在潜在的风险，电路级网关有可能放过有害的数据包，使其顺利到达防火墙后面的服务器。

总之，电路级网关具有如下优点：

(1) 对网络性能有一定程度的影响。由于其工作层次比包过滤防火墙高，因此性能比包过滤防火墙稍差，但是与应用代理防火墙相比，其性能要好很多。

(2) 切断了外部网络与防火墙后的服务器直接连接。外网客户机与内网服务器之间的通信需要通过电路级代理实现，同时电路级代理可以对 IP 层的数据错误进行校验。

(3) 比静态或动态包过滤防火墙具有更高的安全性。在理论上，防火墙实现的层次越高，过滤检查的项目就越多，安全性就越好。由于电路级网关可以提供认证功能，因此其安全性要优于包过滤防火墙。

电路级网关具有如下缺点：

(1) 具有一些包过滤防火墙固有的缺陷，例如，电路级网关不能对数据净荷进行检测，因此无法抵御应用层的攻击等。

(2) 仅提供一定程度的安全性。由于电路级网关在设计理论上存在局限性，工作层次决定了它无法提供最高的安全性。只有到了应用级网关的级别，安全问题才能从理论上得到彻底解决。

(3) 电路级网关防火墙存在的另外一个问题是：当增加新的内部程序或资源时，往往需要对许多电路级网关的代码进行修改（SOCKS 例外）。

12.6 应用级网关

应用级网关与包过滤防火墙不同，包过滤防火墙能对所有不同服务的数据流进行过滤，而应用级网关则只能对特定服务的数据流进行过滤。包过滤器不需要了解数据流的细节，它只查看数据包的源地址和目的地址或检查 UDP/TCP 的端口号和某些标志位。应用级网关必须为特定的应用服务编写特定的代理程序。这些程序被称为“服务代理”，在网关内部分别扮演客户机代理和服务器代理的角色。当各种类型的应用服务通过网关时，它们必须经过客户机代理和服务器代理的过滤。应用级网关的逻辑结构如图 12-23 所示。

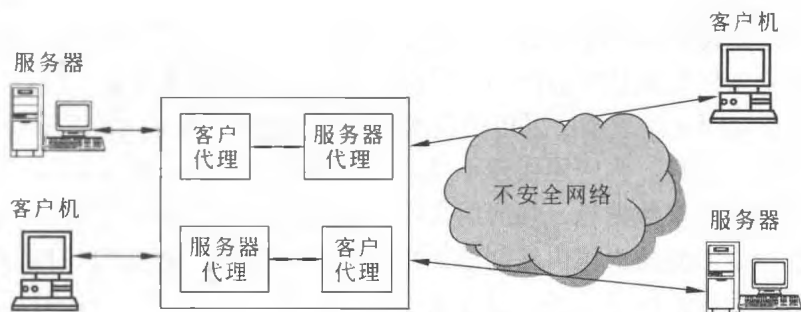


图 12-23 应用级网关的逻辑结构

12.6.1 工作原理

与电路级网关一样，应用级网关截获进出网络的数据包，运行代理程序来回复制和传递通过网关的信息，起着代理服务器的作用。它可以避免内网中的可信服务器或客户机与外网中某个不可信主机之间的直接连接。

应用级网关上所运行的应用代理程序与电路级网关有两个重要的区别：

(1) 代理是针对应用的。

(2) 代理对整个数据包进行检查，因此能在 OSI 模型的应用层上对数据包进行过滤。应用级网关的工作层次如图 12-24 所示。

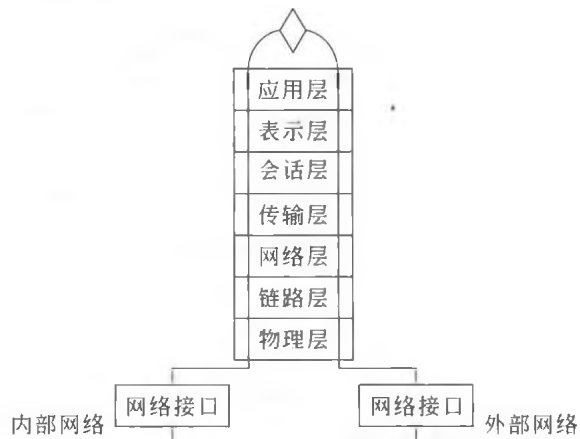


图 12-24 应用级网关的工作层次

与电路级网关不同，应用级网关必须针对每个特定的服务运行一个特定的代理，它只能对特定服务所生成的数据包进行传递和过滤。例如，HTTP 代理只能复制、传递和过滤 HTTP 业务流。如果一个网络使用了应用级网关防火墙，而且网关上没有运行某些应用服务的代理，那么这些服务的数据包都不能进出网络。例如，如果应用级网关防火墙上运行了 FTP 和 HTTP 代理，那么只有这两种服务的数据包才能通过防火墙，所有其他服务的数据包均被禁止。

应用级网关防火墙上运行的代理程序对数据包进行逐个检查和过滤，而不是简单地复制数据让数据包轻易地通过网关。特定的应用代理检查通过网关的每个数据包，在 OSI 模型的应用层上验证数据包内容。这些代理可以对应用协议中的特定信息或命令进行过滤，这就是所谓的关键词过滤或命令字过滤。例如，FTP 应用代理能够过滤许多命令字，以便对特定用户实现更加精细的控制，以保护 FTP 服务器免遭非法入侵。

当前，应用级网关防火墙所采用的技术叫做“强应用代理”。强应用代理技术提高了应用级网关的安全等级。强应用代理不是对用户的整个数据包进行复制，而是在防火墙内部创建一个全新的空数据包。强应用代理将那些可接收的命令或数据，从防火墙外部的原始数据包中复制到防火墙内新建的数据包中。然后，强应用代理将此新数据包发送给防火墙后面受保护的服务器。通过采用此项技术，强应用代理能够降低各类隐信道攻击所带来的风险。

与普通静态或动态包过滤防火墙相比,应用级网关防火墙在更高层上过滤信息,并且能够自动地创建必要的包过滤规则,因此它们比传统的包过滤防火墙更容易配置。

由于应用级网关防火墙对整个数据包进行检查,因此它是当前已有的最安全的防火墙结构之一。虽然应用级网关防火墙具有很高的安全性,但是它有一个固有的缺点,那就是缺乏透明性。此外,缺乏对新应用、新协议的支持也成了制约应用级网关发展的主要障碍。

随着软件技术从原来的 16b 编码转向当前的 32b 编码,再加上 SMP 等新技术的出现,今天的许多应用级网关防火墙既有很高的安全性,也有很好的透明性。此时,公网或内网中的用户不会意识到他们正在通过防火墙访问 Internet。

12.6.2 安全性讨论

包过滤防火墙无须对数据净荷进行检查,它仅检查数据包的源地址和目的地址,也可能检查 UDP 或 TCP 的端口号或标志位。由于应用级网关要对特定服务数据包的细节进行检查,因此它比包过滤防火墙更复杂。

应用级网关不是采用通用机制处理所有应用服务的数据包,而是采用特定的代理程序处理特定应用服务的数据包。例如,针对电子邮件的应用代理程序能理解 RFC 822 头信息和 MIME 编码格式的附件,也可能识别出感染病毒的软件。这类过滤器通常采用存储转发方式工作。

应用级网关还有另外一个优点:它容易记录和控制所有进出网络的数据流。这对于某些环境来说非常关键。它可以对电子邮件中的关键词进行过滤,也可以让特定的数据通过网关。它还能对网页的查询请求进行过滤,使其与安全策略一致,以禁止员工在工作时间上网看新闻。它也能剔除危险的电子邮件附件。

不管网络中的其他防火墙采用何种技术,电子邮件通常必须经过应用级网关的过滤。即使网络中没有安装防火墙,也必须安装电子邮件网关。它还能去掉内部主机的名称,因为此名称中可能含有一些有价值的信息。它甚至还可以进行数据流分析、内容分析并形成日志,以便事后查看被泄漏的信息。

注意:以上描述的安全机制仅用来防止攻击者从外部发起攻击。但是如果网络内部有不法用户想导入含有病毒的文件,这些安全机制将无能为力。当然,这类问题的防范超出了防火墙的功能范围。

应用级网关的主要缺点是:对于大多数应用服务来说,它需要编写专门的用户程序或不同的用户接口。在实践中,这意味着应用级网关只能支持一些非常重要的服务。对于一些专用的协议或应用,应用级网关将无法加以过滤。对于许多新出现的应用服务,应用级网关则无能为力,因为用户必须重新开发新的代理程序,而这需要时间。目前,它仅能对有限的几个常用的应用服务进行过滤,如 HTTP、FTP、SMTP、POP3、Telnet 等。

在复杂的网络环境中,应用级网关显得不太实用,并且可能超负荷运行,以致不能正常工作。如果应用级网关的实现依赖于操作系统的 Inetd 守护程序,则其最大并发连接数目将受到严重限制。今天的网络环境对并行会话的要求非常高,这就要求应用级网关

防火墙对网络环境有很强的适应性。因此，是否采用应用级网关防火墙，取决于用户的选择。如果用户为满足某些特殊的安全需求而采用应用级网关防火墙，那么用户就要承担一定的风险。如果内网中的用户太多、流量太大，就可能因所支持的并发连接数不够而造成过滤速度缓慢或死机。

当然，从安全的角度看，人们更偏向于采用应用级网关防火墙。由于它在应用层上对数据进行过滤，因此更安全。网关也可以支持其他的应用，例如，可以让它承担域名服务器或邮件服务器的任务。应用级网关防火墙隐藏了内部主机的 IP 地址或主机名，对于外部的网络用户来说，这些信息是不可见的。当数据包流出内网的时候，防火墙将消息头中的专用 IP 地址和主机名去掉；当数据包自外网流入内网时，防火墙的域名服务器对数据包进行解析，再发往内网的用户。因此，对于外部网络来说，防火墙看起来既是源点也是终点。

应用级网关可以解决 IP 地址缺乏的问题。网络管理员可以将大量的专用 IP 地址分配给内网用户，使内部主机的 IP 地址分配变得非常容易。由于应用级网关对 Internet 隐藏了内部的专用 IP 地址，因此它只需要 ISP 提供几个静态 IP 地址即可。

用户可使用应用级网关上运行的 FTP 代理程序传输文件。内部用户通过登录防火墙上传或下载文件，外部用户也一样。在进行匿名文件传输时，用户先将文件发给防火墙，再由防火墙将文件发出。这种工作方式也同样适用于 Telnet 或 rlogin 会话：用户首先远程登录到防火墙上，防火墙再远程登录到外部网络。E-mail 及由网站提供的某些服务均采用这种安全工作模式。这样，内网用户就可以通过应用级网关对外部用户提供服务。当然，用户可以采用 Kerberos 安全协议来管理内外网用户之间的会话。

有的商用防火墙可为用户提供应用级网关软件。用户可与制造商签署保密协议，让他们提供对许多专用协议的支持。但是，究竟是否真正需要应用级网关支持这些协议，网络管理员要对内网的安全策略仔细研究。即使应用级网关能够对这些专用协议进行过滤，如果根本不需要这些协议，就应该去掉它们。在应用级网关上增加对这些协议的支持，只会增加防火墙的负担，从而降低防火墙的性能。

TIS (Trusted Information Systems) 防火墙工具包是一种非常流行的应用级网关软件。读者可以从网上自由下载。该工具包包括 Telnet 网关、FTP 网关、rlogin 网关和 SSL 网关等。另外，还有一些专门为特定服务编写的应用代理软件包，如 Squid 等。对这些软件加以修改，它们就可以应用于防火墙中。

总之，应用级网关的主要优点如下所述：

(1) 在已有的安全模型中安全性较高。由于工作于应用层，因此应用级网关防火墙的安全性取决于厂商的设计方案。应用级网关防火墙完全可以对服务（如 HTTP、FTP 等）的命令字过滤，也可以实现内容过滤，甚至可以进行病毒的过滤。

(2) 具有强大的认证功能。由于应用级网关在应用层实现认证，因此它可以实现的认证方式比电路级网关要丰富得多。

(3) 具有超强的日志功能。包过滤防火墙的日志仅能记录时间、地址、协议、端口，而应用级网关的日志要明确得多。例如，应用级网关可以记录用户通过 HTTP 访问了哪些网站页面、通过 FTP 上传或下载了什么文件、通过 SMTP 给谁发送了邮件，甚至邮件

的主题、附件等信息，都可以作为日志的内容。

(4) **应用级网关防火墙的规则配置比较简单**。由于应用代理必须针对不同的协议实现过滤，所以管理员在配置应用级网关时关注的重点就是应用服务，而不必像配置包过滤防火墙一样还要考虑规则顺序的问题。

应用级网关的主要缺点如下所述：

(1) **灵活性很差**：对每一种应用都需要设置一个代理。由此导致的问题很明显，每当出现一种新的应用时，必须编写新的代理程序。由于目前的网络应用呈多样化趋势，这显然是一个致命的缺陷。在实际工作中，应用级网关防火墙中集成了电路级网关或包过滤防火墙，以满足人们对灵活性的需求。

(2) **配置复杂**：增加了管理员的工作量。由于各种应用代理的设置方法不同，因此对于不是很精通计算机网络的用户而言，难度可想而知。对于网络管理员来说，当网络规模达到一定程度时，其工作量很大。

(3) **性能不高**：有可能成为网络的瓶颈。虽然目前的 CPU 处理速度还是保持以摩尔定律的速度增长，但是周边系统的处理性能（如磁盘访问性能等）远远落后于运算能力的提高，很多时候系统的瓶颈根本不在于处理器的性能。目前，应用级网关的性能依然远远无法满足大型网络的需求，一旦超负荷，就有可能发生宕机，从而导致整个网络中断。

12.7

状态检测防火墙

状态检测技术是防火墙近几年才应用的新技术。传统的包过滤防火墙只是通过检测 IP 包头的相关信息来决定数据流的通过还是拒绝，而状态检测技术采用的是一种基于连接的状态检测机制，将属于同一连接的所有包作为一个数据流的整体看待，构成连接状态表，通过规则表与状态表的共同配合，对表中的各个连接状态因素加以识别。这里动态连接状态表中的记录可以是以前的通信信息，也可以是其他相关应用程序的信息，因此，与传统包过滤防火墙的静态过滤规则表相比，它具有更好的灵活性和安全性。

12.7.1 工作原理

先进的状态检测防火墙读取、分析和利用了全面的网络通信信息和状态，如下所述：

(1) **通信信息**：即所有 7 层协议的当前信息。防火墙的检测模块位于操作系统的内核，在网络层之下，能在数据包到达网关操作系统之前对它们进行分析。防火墙先在低协议层上检查数据包是否满足企业的安全策略，对于满足的数据包，再从更高协议层上进行分析。它验证数据的源地址、目的地址和端口号、协议类型、应用信息等多层的标志，因此具有更全面的安全性。

(2) **通信状态**：即以前的通信信息。对于简单的包过滤防火墙，如果要允许 FTP 通过，就必须做出让步而打开许多端口，这样就降低了安全性。状态检测防火墙在状态表中保存以前的通信信息，记录从受保护网络发出的数据包的状态信息，如 FTP 请求的服务器地址和端口、客户端地址和为满足此次 FTP 临时打开的端口，然后，防火墙根据该

表内容对返回受保护网络的数据包进行分析判断，这样，只有响应受保护网络请求的数据包才被放行。这里，对于 UDP 或 RPC 等无连接的协议，检测模块可创建虚会话信息用来进行跟踪。

（3）应用状态：即其他相关应用的信息。状态检测模块能够理解并学习各种协议和应用，以支持各种最新的应用，它比代理服务器支持的协议和应用要多得多；并且，它能从应用程序中收集状态信息并存入状态表中，以供其他应用或协议做检测策略。例如，已经通过防火墙认证的用户可以通过防火墙访问其他授权的服务。

（4）操作信息：即在数据包中能执行逻辑运算或数学运算的信息。状态监测技术采用强大的面向对象的方法，基于通信信息、通信状态、应用状态等多方面因素，利用灵活的表达式形式，结合安全规则、应用识别知识、状态关联信息及通信数据，构造更复杂的、更灵活的、满足用户特定安全要求的策略规则。

状态检查防火墙将动态包过滤、电路级网关和应用级网关等各项技术结合在一起。由于状态检测防火墙可以在 OSI 模型的所有 7 个层次上进行过滤，所以在理论上应该具有很高的安全性，如图 12-25 所示。但是，现在的大多数状态检测防火墙只工作于网络层，而且只作为动态包过滤器对进出网络的数据进行过滤。因此，它对数据包的过滤还基于对源地址、目的 IP 地址及端口号的检查。有些企业声称，这是管理员在配置防火墙时出错，许多管理员则抱怨采用状态监测功能将造成防火墙超负荷运行，从而使其应用受到限制。

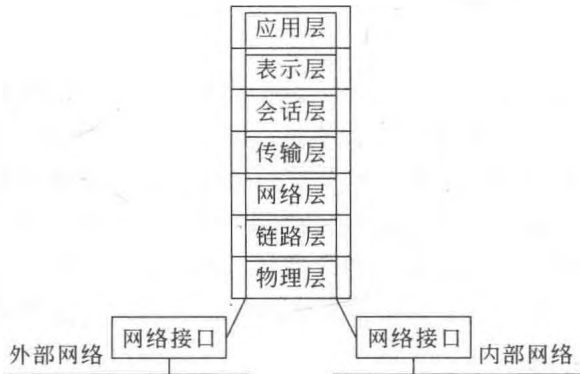


图 12-25 状态检测防火墙在所有 7 层上进行过滤

12.7.2 安全性分析

尽管状态检测防火墙潜在地具有在全部 7 层上过滤数据包的能力，但是许多管理员在安装防火墙时仅让其运行在 OSI 的网络层上，作为动态包过滤防火墙使用。前面已指出，状态检测防火墙也可以作为电路级网关工作，以确定是否允许某个会话中的数据包通过防火墙。例如，状态检测防火墙可以验证输入数据包的 SYN、ACK 标志位和序列号是否符合逻辑。然而，在许多实现方案中，状态检测防火墙仅被当作动态包过滤防火墙使用，并且允许采用单个 SYN 数据包建立新的连接，这是非常危险的。有的状态检测防火墙方案不能对内部主机发出的数据包的序列号进行检测，这可能导致安全缺陷：一

个内部主机可以非常容易地伪装成其他内部主机的 IP 地址，在防火墙上为进入内网的连接打开一扇门。

最后需要说明的是，状态检测防火墙可以模仿应用级网关。状态检测防火墙可以在应用层上对每个数据包的内容进行评估，并且能够确保这些内容与管理员根据本机构的安全策略所设置的过滤规则相匹配。与应用级网关一样，状态检测防火墙可以丢弃那些在应用头（Application Header）中含有特定指令的数据包。例如，管理员可以配置状态检测防火墙，让它丢弃包含“Put”指令的数据包。然而，当采用单线程的状态检测防火墙进行应用层过滤时，其性能会受到很大的影响。因此，管理员为获得较高的吞吐率以满足网络对速度的需求，通常将状态检测防火墙配置成动态包过滤防火墙使用。实际上，状态检测防火墙的默认配置就是采用动态包过滤，而没有对许多广泛使用的协议（如 HTTP）实施状态检测。

与应用级网关不同，状态检测防火墙没有打破用“客户/服务器”模型来分析应用层数据。应用级网关创建了两个连接：一个连接在可信客户机和网关之间，另一个连接在网关和不可信主机之间。网关在这两个连接之间复制信息。这是应用代理和状态检测争论的核心。有些管理员坚持认为这一配置确保了高安全性，而有些管理员则认为这一配置降低了系统的性能。为了提供安全的连接，状态检测防火墙能够在 OSI 的应用层上截获和检查每个数据包。遗憾的是，单线程状态检测进程给防火墙性能带来很大的影响，所以管理员通常不采用这一配置。

状态检测防火墙依靠检测引擎中的算法来识别和处理应用层数据。这些算法将数据包与授权数据包的已知比特模式相比较。有些厂商声称，在理论上，它们的状态检测防火墙在过滤数据包时，要比特定应用代理更加高效。然而，许多状态检测引擎是以单线程工作的，显著地缩小了状态检测防火墙与应用级网关之间的差别。例如，不做状态检测防火墙的 SMP 多架构防火墙与普通状态检测防火墙相比，吞吐量之比为 4:1，并行会话能力之比高达 12:1。此外，由于受状态检测引擎中所使用的检测语言的限制，现在人们通常使用应用级网关来代替状态检测防火墙。

总之，状态检测防火墙具有以下优点：

- （1）具备动态包过滤的所有优点，同时具有更高的安全性。因为增加了状态检测机制，所以能够抵御利用协议细节进行的攻击。
- （2）没有打破客户/服务器模型。
- （3）提供集成的动态（状态）包过滤功能。
- （4）当以动态包过滤模式运行时，其速度很快；当采用 SMP 兼容的动态包过滤时，其运行速度更快。

状态检测防火墙具有以下缺点：

- （1）由于状态检测引擎采用单线程进程，此设计将对防火墙的性能产生很大影响。许多用户将状态检测防火墙当作动态包过滤防火墙使用，过滤的层次仅限于网络层与传输层，无法对应用层内容进行检测，也就无法防范应用层攻击。
- （2）许多人认为，没有打破“客户/服务器”结构会产生不可接受的安全风险，因为黑客可以直接与受保护的服务器建立连接。

(3) 如果实现方案依赖于操作系统的 Inetd 守护程序, 其并发连接数量将受到严重限制, 从而不能满足当今网络对高并发连接数量的要求。

(4) 仅能提供较低水平的安全性。没有一种状态检测防火墙能提供高于通用标准 EAL2 的安全性。EAL2 等级的安全产品不能用于对专网的保护。

12.8 切换代理

12.8.1 工作原理

切换代理 (Cutoff Proxy) 实际上是动态 (状态) 包过滤器和电路级代理的结合。在许多实现方案中, 切换代理首先起电路级代理的作用, 以验证 RFC 建议的 3 步握手, 然后再切换到动态包过滤的工作模式下。因此, 切换代理首先工作于 OSI 的会话层, 即第 5 层, 当连接完成后, 再切换到动态包过滤模式, 即工作于 OSI 的第 3 层。切换代理的工作过程如图 12-26 所示。

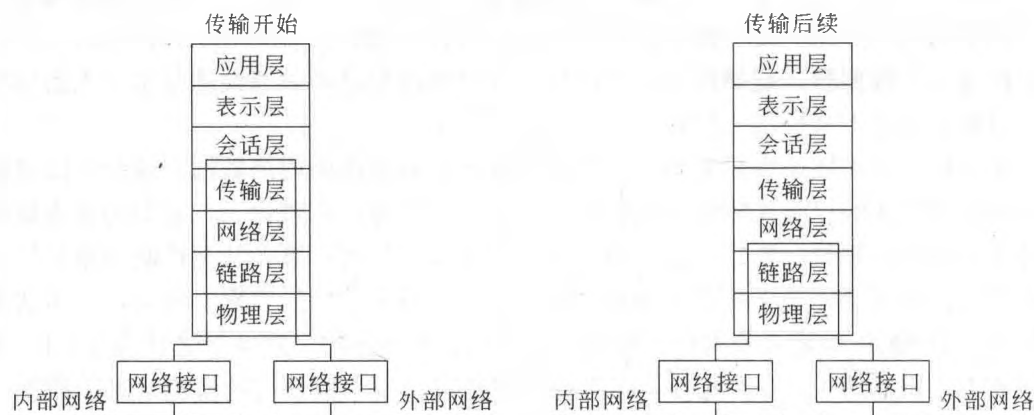


图 12-26 切换代理的工作过程

有些厂商已经将切换代理的过滤能力拓展到应用层, 使其在切换到动态包过滤模式之前能够处理有限的认证信息。

12.8.2 安全性讨论

前面已讨论了切换代理的工作原理, 现在来分析切换代理的缺点。我们知道, 切换代理与传统的电路级代理不同: 电路级代理能在连接持续期间打破“客户/服务器”模式, 而切换代理却不能。远端的客户机与防火墙后面受保护的服务器之间仍然能够建立直接的连接。切换代理可以在安全性和性能两者之间找到一个平衡点。在谈及切换代理时, 许多厂商吹嘘切换代理不仅能够提供与电路级网关相同的安全性, 而且能够提供与动态包过滤防火墙相同的性能。

我们认为, 不同类型的防火墙结构在 Internet 安全中都有不同的定位。如果安全策略规定需要对一些基本的服务进行认证并检查 3 步握手, 而且不需要打破“客户/服务器”

模式，那么切换代理就是一个非常合适的选择。然而，管理员必须清醒地认识到，切换代理决不等于电路级代理，因为在建立连接期间，它并未打破“客户/服务器”的工作模式。

总之，切换代理具有以下优点：

- (1) 与传统的电路级网关相比，它对网络性能造成的影响要小。
- (2) 由于对 3 步握手进行了认证，所以降低了 IP 欺骗的风险。

切换代理具有以下缺点：

- (1) 它不是一个电路级网关。
- (2) 它仍然具有动态包过滤器遗留的许多缺陷。
- (3) 由于没有检查数据包的净荷部分，因此具有较低的安全性。
- (4) 难于创建规则（受先后次序的影响）。
- (5) 其安全性不及传统的电路级网关。

12.9

空气隙防火墙

12.9.1 工作原理

空气隙防火墙（Air Gap）俗称“安全网闸”，它是现有防火墙结构中的新成员。安全网闸技术是模拟人工拷盘的工作模式，通过电子开关的快速切换实现两个不同网段的数据交换的物理隔离安全技术。安全网闸技术源于被称为“Air Gap”的安全技术，它本意是指由空气形成的用于隔离的缝隙。在网络安全技术中，主要指通过专用的硬件设备在物理不连通的情况下，实现两个独立网络之间的数据安全交换和资源共享。目前，有关空气隙防火墙技术的是非争论还在继续。其实，空气隙防火墙的工作原理非常简单。首先，外部客户机与防火墙之间的连接数据被写入一个具有 SCSI 接口的高速硬盘中，然后内部的连接再从该 SCSI 硬盘中读取数据。由于防火墙切断了客户机到服务器的直接连接，并且对硬盘数据的读/写操作都是独立进行的，因此人们相信空气隙防火墙能够提供高度的安全性。其结构如图 12-27 所示。

从图 12-27 中可以看出，它由 3 个组件构成：*A* 网处理机、*B* 网处理机和 GAP 开关设备。可以很清楚地看到连接两个网络的 GAP 设备不能同时连接到相互独立的 *A* 网和 *B* 网中，即 GAP 在某一时刻只与其中某个网络相连。GAP 设备连接 *A* 网时，它是与 *B* 网断开的，*A* 网处理机把数据放入 GAP 中；GAP 在接收完数据后自动切换到 *B* 网，同时，GAP 与 *A* 网断开；*B* 网处理机从 GAP 中取出数据，并根据合法数据的规则进行严格的检查，判断这些数据是否合法，若为非法数据，则删除它们。同理，*B* 网也以同样的方式通过 GAP 将数据安全地交换到 *A* 网中。从 *A* 网处理机往 GAP 放入数据开始，到 *B* 网处理机从 GAP 中取出数据并检查结束，就完成了一次数据交换。GAP 就这样在 *A* 网处理机与 *B* 网处理机之间来回往复地进行实时数据交换。在通过 GAP 交换数据的同时，*A* 网和 *B* 网仍然是相互隔离的。

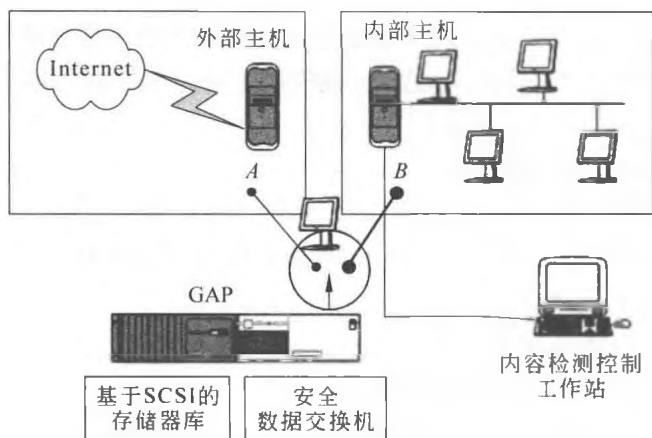


图 12-27 空气隙防火墙结构

安全网闸如何保证网络的安全性呢？首先，这两个网络一直是隔离的，在两个网络之间只能通过 GAP 来交换数据。当两个网络的处理机或 GAP 三者中的任何一个设备出现问题时，都无法通过 GAP 进入另一个网络，因为它们之间没有物理连接；第二，GAP 只交换数据，不直接传输 TCP/IP 数据包，这样就避免了 TCP/IP 的漏洞；第三，任何一方接收到数据，都要对数据进行严格的内容检测和病毒扫描，严格控制非法数据的交流。GAP 安全性的高低关键在于其对数据内容检测的强弱。若不做任何检测，虽然是隔离的两个网络，也能传输非法数据、病毒或木马，甚至利用应用协议漏洞通过 GAP 设备从一个网络直接进入另一个网络。此时，GAP 的作用将大打折扣。

空气隙防火墙的工作原理与应用级网关非常相似，要把空气隙技术同应用级网关技术加以区分是非常困难的。两者的主要差别是：空气隙技术分享的是一个公共的 SCSI 高速硬盘，而应用级网关技术分享的是一个公共的内存。另外，空气隙防火墙由于采用了外部进程（SCSI 驱动），所以性能上受到限制，而应用级网关防火墙是在内核存储空间上运行内核硬化的安全操作系统，在同样安全性的情况下，性能却大大地提高了。

关于空气隙防火墙的各项指标还有待于由第三方权威机构进行检验。但是，目前大多数空气隙防火墙产品的性能远远地落后于传统的应用级网关防火墙产品。如果没有得到权威机构提供的安全性报告，对许多系统管理员来说，使用空气隙防火墙不能不考虑性能上的损失。

12.9.2 安全性分析

尽管作为物理安全设备，安全网闸提供的高安全性是显而易见的，但是由于其工作原理的特殊性，决定了安全网闸存在一些不可避免的缺陷。

安全性和易用性始终是矛盾的。在已有的防火墙、VPN 及 AAA 认证设备等安全设施的多重构架环境中，安全网闸产品的加入使网络日趋复杂化：正常的访问连接越来越多地受到各种不可见和不易见的因素的干扰和影响；已经配置好的各种网络产品和安全产品，可能由于安全网闸的配置不当而受到影响；许多网络由于采用了多重过滤的安全结构，其性能本来就有所下降，而安全网闸的加入使网络性能瓶颈问题更加突出。因为

电子开关切换速率的固有特性和安全过滤功能的复杂化,目前安全网闸的交换速率已接近该技术的理论速率极限。可以预见,在不久的将来,随着高速网络技术的发展,安全网闸在交换速率上的问题将会成为阻碍网络数据交换的重要因素。

总之,空气隙防火墙具有以下优点:

- (1) 切断了与防火墙后面服务器的直接连接,消除了隐信道攻击的风险。
- (2) 采用强应用代理对协议头长度进行检测,因此能够消除缓冲器溢出攻击。
- (3) 与应用级网关结合使用,空气隙防火墙能提供很高的安全性。

空气隙防火墙具有以下缺点:

- (1) 它会在很大程度上降低网络的性能。
- (2) 只支持静态数据交换,不支持交互式访问。
- (3) 适用范围窄,必须根据具体应用开发专用的交换模块。
- (4) 系统配置复杂,安全性在很大程度上取决于网络管理员的技术水平。
- (5) 结构复杂,实施费用较高。
- (6) 可能造成其他安全产品不能正常工作,并带来瓶颈问题。

12.10

分布式防火墙

传统意义上的边界防火墙用于限制被保护系统内部网络与外部网络(通常是因特网)之间进行信息存取、传递的操作,它所处的位置在内部网络与外部网络之间。实际上,所有以前出现的各种不同类型的防火墙,从简单的包过滤到应用层代理以至自适应代理,都是基于一个共同的假设,那就是防火墙把内部网络一端的用户看成是可信的,外部网络一端的用户则都被作为潜在的攻击者来对待。这种假设是整个防火墙开发的指导思想和工作机制。但随着最近几年各种网络技术和各种新的攻击情况不断出现,防火墙“防外不防内”的特点成为导致安全隐患的一个新因素。据统计,80%的攻击和越权访问来自于内部,而边界防火墙在对付网络内部威胁时束手无策。如何控制内部网络的攻击成为一个新的课题,一种新型防火墙——“分布式防火墙”应运而生。

12.10.1 工作原理

分布式防火墙通常由 3 个部分组成,分别是网络防火墙、主机防火墙和管理中心。

网络防火墙用于内部网与外部网之间,以及内部网各子网之间的防护。与传统边界式防火墙相比,它多了一种用于对内部子网之间的安全防护层,这样整个网络的安全防护体系就显得更加全面可靠。不过在功能上与传统的边界式防火墙类似。

主机防火墙用于对网络中的服务器和桌面机进行防护。这也是传统边界式防火墙所不具有的,也算是对传统边界式防火墙在安全体系方面的一个完善。主机防火墙通常是内核模式应用,它位于操作系统 OSI 栈的底部,直接面对网卡,它们对所有的信息流进行过滤与限制。也有一些国际著名网络设备开发商(如 3COM 和 Cisco 等)以 PCI 卡或

PCMCIA 卡的形式开发了主机防火墙。

管理中心是一个服务器软件，负责总体安全策略的策划、管理、分发及日志的汇总。

这里的主机防火墙与个人防火墙有相似之处，如它们都对应个人系统，但其差别又是本质性的。首先它们管理方式迥然不同，个人防火墙的安全策略由系统使用者自己设置，目标是防外部攻击，而针对桌面应用的主机防火墙的安全策略由整个系统的管理员统一安排和设置，除了对该桌面机起到保护作用外，也可以对该桌面机的对外访问加以控制，并且这种安全机制是桌面机的使用者不可见和不可改动的。其次，不同于个人防火墙面向个人用户，针对桌面应用的主机防火墙是面向企业级客户的，它与分布式防火墙其他产品共同构成一个企业级应用方案，并可以形成一个安全策略中心统一管理、安全检查机制分散布置的分布式防火墙体系结构。

12.10.2 分布式防火墙的优缺点

1. 优点

(1) 增强了系统安全性。增加了针对主机的入侵检测和防护功能，加强了对来自内部攻击的防范，可以实施全方位的安全策略。

(2) 提高了系统性能。消除了结构性瓶颈问题，提高了系统性能。

(3) 提供了系统的扩展性。分布式防火墙随系统扩充提供了安全防护无限扩充的能力。

(4) 可实施主机策略。对网络中的各节点可以起到更安全的防护。

2. 缺点

(1) 系统部署时间比较长、复杂度高，后期的维护工作量较大。

(2) 软件实现的主机防火墙有可能受到来自系统内部的攻击，或者受到系统自身安全性的影响。

12.11

防火墙的发展趋势

未来防火墙的发展趋势是朝高速、多功能化、更安全的方向发展。为了满足高速化，防火墙必须从现在的以软件为主向以硬件为主转化。硬件化评判的标准是看在数据转发控制的过程中，是由软件完成还是硬件完成。以往的防火墙产品，大多通过编写软件，利用 CPU 的运算能力进行数据处理，而硬件化的系统应该使用专用的芯片级处理机制，如使用 ASIC 防火墙芯片、网络处理器芯片和 FPGA 芯片。

12.11.1 硬件化

在网络带宽日渐增大的情况下，防火墙的性能成为关注的焦点。要解决性能方面的问题，唯一的出路就是硬件化。如同路由器的发展经过了由软到硬的转变一样，防火墙产品也走到了这个关口。从性能上看传统的 CPU 主机+软件的方式，无论是系统总线、

I/O 接口，还是 CPU 的处理能力都显得力不从心，防火墙正在成为网络的最大的瓶颈。因此如何把防火墙从软件转变为硬件以提高性能，成为防火墙发展道路上的一个新问题。

目前防火墙的硬件化主要有两条路：基于 ASIC 芯片的防火墙和基于网络处理器的防火墙。下面分析这两种技术架构各自的特点。

网络处理器是专门为处理数据包而设计的可编程处理器，它的硬件特点是内部包含多个数据处理引擎，这些引擎可以并发进行数据处理工作，在处理 2~4 层的分组数据上比通用处理器具有明显的优势。网络处理器对数据包处理的一般性任务进行了优化，如 TCP/IP 数据的校验和计算、包分类、路由查找等。同时硬件体系结构的设计也大多采用高速的接口技术和总线规范，具有较高的 I/O 能力。这样基于网络处理器设计的网络设备的包处理能力得到了很大提升。它具有以下几个方面的特性：完全的可编程性、简单的编程模式、最大化系统灵活性、高处理能力、高度功能集成、开放的编程接口和第三方支持能力。基于网络处理器架构的防火墙与基于通用 CPU 架构的防火墙相比，在性能上可以得到本质的提高。网络处理器能弥补通用 CPU 架构性能的不足，同时又不需要具备开发基于 ASIC 技术的防火墙所需要的大量资金和技术积累。更关键的是，网络处理器是可编程的，对于防火墙产品，这种灵活性是非常必要的。

第 2 种方案是采用基于 ASIC 技术的架构。Netscreen 公司是采用该技术的代表厂家。采用 ASIC 技术可以为防火墙应用设计专门的数据包处理流水线，优化存储器等资源的利用，是公认的实现千兆线速防火墙、满足千兆骨干级应用的技术方案。Netscreen 公司也因此取得了令人瞩目的成功。但 ASIC 技术开发成本高，开发周期长且难度大，一般的防火墙厂商不具备相应的技术和资金实力。另外，ASIC 的灵活性也是阻碍其被采用的原因之一。目前也有些设计方案采用 FPGA+ASIC 的方式，以获取足够的性能和相对的灵活性。

12.11.2 多功能化

多功能也是防火墙的发展方向之一，鉴于目前路由器和防火墙价格都比较高，组网环境也越来越复杂，一般用户总希望防火墙可以支持更多的功能，满足组网和节省投资的需要。例如，防火墙支持广域网口，并不影响安全性，但在某些情况下却可以为用户节省一台路由器，支持部分路由器协议，如路由、拨号等，可以更好地满足组网需要；支持 IPSec VPN，可以利用因特网组建安全的专用通道，既安全又节省了专线投资。据 IDC 统计，国外 90% 的加密 VPN 都是通过防火墙实现的。

不仅如此，防火墙还被要求不再仅仅是一个被动安全产品，要具有主动安全的功能，比如具有入侵检测功能或者具备与入侵检测产品联动的功能，以实现攻击行为的及时阻断。防火墙需要提供认证机制，无论是防火墙本地认证或者是第三方认证，比如 Radius 等，来实现对不同的内部用户，提供不同的网络访问权限。甚至随着 IPv6 网络的出现，从 IPv4 到 IPv6 网络的相互转换也可能作为对防火墙功能的一个新的需求。作为网络出口（入口）的设备，由于路由器功能的相对明确，越来越多的功能都将被赋予防火墙。

12.11.3 安全性

调查显示，用户对于防火墙关注的重点是性能、功能和易用性，却往往忽视了防火墙最重要的一点：安全性。但是，随着防火墙产品性能与功能的提升，未来对防火墙的价值取向将逐步回归到本质——安全。从前面提到的各种防火墙的优缺点可以看出，目前广泛应用的基于状态检测的包过滤防火墙，其安全性并不是最高的。由于检测的深度只能达到传输层，对于针对应用层的攻击无能为力，安全性有待进一步提高。随着算法和芯片技术的发展，防火墙会更多地参与应用层分析，为应用提供更安全的保障。在信息安全的发展与对抗过程中，防火墙技术一定会日新月异，从而在信息安全的防御体系中起到堡垒的作用。

习 题

一、填空题

1. 防火墙应位于_____。
A. 公司网络内部 B. 公司网络外部
C. 公司网络与外部网络之间 D. 都不对
2. 应用网关的安全性_____包过滤防火墙。
A. 不如 B. 超过 C. 等于 D. 都不对
3. 防火墙可以分为_____、_____、_____、_____、_____和_____ 7 种类型。
4. 静态包过滤防火墙工作于 OSI 模型的_____层上，它对数据包的某些特定域进行检查，这些特定域包括：_____、_____、_____、_____和_____。
5. 动态包过滤防火墙工作于 OSI 模型的_____层上，它对数据包的某些特定域进行检查，这些特定域包括：_____、_____、_____、_____和_____。
6. 电路级网关工作于 OSI 模型的_____层上，它检查数据包中的数据分别为_____、_____、_____、_____、_____和_____。
7. 应用级网关工作于 OSI 模型的_____层上，它可以对整个数据包进行检查，因此其安全性最高。
8. 状态检测防火墙工作于 OSI 模型的_____层上，所以在理论上具有很高的安全性，但是现有的大多数状态检测防火墙只工作于_____层上，因此其安全性与包过滤防火墙相当。
9. 切换代理在连接建立阶段工作于 OSI 模型的_____层上，当连接建立完成之后，再切换到_____模式，即工作于 OSI 模型的_____层上。
10. 空气隙防火墙也称做_____，它在外网和内网之间实现了真正的_____。

二、思考题

1. 防火墙一般有几个接口？什么是防火墙的非军事区（DMZ）？它的作用是什么？
2. 为什么防火墙要具有 NAT 功能？在 NAT 中为什么要记录端口号？

3. 系统中提到了 NAT 的几种实现方式, 试着给出 M-N 的 NAT 转换算法。
4. 防火墙必须同时兼有路由器功能吗? 为什么?
5. 简述静态包过滤防火墙的工作原理, 并分析其优缺点。动态包过滤防火墙与静态包过滤防火墙的主要区别是什么?
6. 分组过滤的 3 大操作是什么?
7. 结合实际操作, 描述动态防火墙在 TCP 连接终止时的状态转换。
8. 电路级网关与包过滤防火墙有何不同? 简述电路级网关的优缺点。
9. 应用级网关与电路级网关有何不同? 简述应用级网关的优缺点。
10. 下载 TIS, 配置应用层网关防火墙。
11. 状态检测防火墙与应用级网关有何不同? 简述状态检测防火墙的优缺点。
12. 切换代理在连接建立阶段工作于会话层, 而在连接完成后工作于网络层, 这样的设计有何好处? 简述切换代理的优缺点。
13. 为什么说空气隙防火墙能够实现物理隔离? 简述空气隙防火墙的优缺点。
14. 防火墙有什么局限性?
15. 软件防火墙与硬件防火墙之间的区别是什么?